



ICS-LTU2022: A dataset for ICS vulnerabilities

Manar Alanazi^{*}, Abdun Mahmood, Mohammad Javed Morshed Chowdhury

Department of Computer Science and Information Technology, School of Engineering and Mathematical Science, La Trobe University, Bundoora, Melbourne, 3086, VIC, Australia

ARTICLE INFO

Keywords:

ICS vulnerabilities
ICS dataset
SCADA
Machine learning
Vulnerability analysis

ABSTRACT

Industrial control systems (ICS) are a collection of control systems and associated instrumentation for controlling and monitoring industrial processes. Critical infrastructure relies on supervisory control and data acquisition (SCADA), a subset of ICS specifically designed for monitoring and controlling industrial processes over large geographic areas. Cyberattacks like the Colonial Pipeline ransomware case have demonstrated how an adversary may compromise critical infrastructure. The Colonial Pipeline ransomware attack led to a week's pipeline shutdown, causing a gas shortage in the United States. As existing vulnerability assessment tools cannot be used in the context of ICS systems, vulnerability datasets specified for ICSs are needed to evaluate the security weaknesses. Our secondary metadata, ICS-LTU2022, consists of multiple features that can be used for vulnerability assessment and risk evaluation in industrial control systems. A description of the dataset, its characteristics, and data analysis are also presented in this paper. Vulnerability analysis was conducted based on the top 10 vulnerabilities in terms of severity, frequency by year, impact, components of the ICS, and common weaknesses. The ICS-LTU2022 vulnerabilities dataset is updated biannually. Our proposed dataset provides security researchers with the most recent ICS critical vulnerabilities.

1. Introduction

ICS refers to integrated hardware and software to monitor and control industrial processes. SCADA is a type of ICS focused on real-time data collection and process control in large-scale operations, including energy, transportation systems, critical manufacturing, and healthcare. Several advantages result from adopting cyber-physical systems with Internet of Things (IoT) environments, including network optimisation, reduced costs, flexibility, and performance efficiency (Sajid et al., 2016). As these systems become more connected and integrated with other platforms, they are exposed to cyber threats. For example, the Colonial Pipeline ransomware attack in May 2021 (Basnet et al., 2021) infected some pipeline computers, forcing the company to shut down the system for a few days. The attack led to gas shortages and emergency declarations in some East Coast states. Additionally, the SolarWinds attacks left over 18,000 SolarWinds customers and network data compromised. A supply chain attack method was used to insert malicious code into the Orion system. It impacted several organisations and government agencies, such as Microsoft, Cisco, and Homeland Security. Additionally, the Triton malware attack on a Saudi petrochemical plant, which targeted safety instrumented systems (SIS), posed a significant risk to human safety and industrial operations (Suthantha et al., 2023). Furthermore, the NotPetya ransomware attack

in 2017 caused widespread disruption to organisations worldwide, including critical infrastructure operators (Lika et al., 2018).

These incidents serve as reminders of the increasing sophistication and frequency of cyberattacks on critical infrastructure. They highlight the urgent need for robust cybersecurity measures and enhanced resilience to protect these essential systems from potential threats. Governments and organisations must continuously invest in improving their security protocols, implementing regular audits, and promoting cybersecurity awareness among employees to mitigate the risks associated with such attacks.

In contrast to traditional computer systems, industrial control systems (ICSs) are more vulnerable to service interruptions because of improper input validation (Guevara and Fradkin, 2021; Stouffer et al., 2011; Paridari et al., 2018). Therefore, analysing and evaluating previous cybersecurity incidents is important to prevent future attacks that can disrupt ICS operations. Due to the critical nature of ICSs and their distributed operational areas, vulnerability assessment and penetration testing are major concerns. In response, artificial intelligence (AI), including machine learning (ML) and deep learning, are being adopted in the field of ICS cybersecurity research to counter cyberattacks against such systems.

Two basic approaches are currently being adopted in intrusion detection research for ICSs. One is the network intrusion detection

^{*} Corresponding author.

E-mail address: ManarAhmedT.ALANAZI@latrobe.edu.au (M. Alanazi).

system (NIDS), which monitors network traffic to identify malicious activities. The second approach is the host intrusion detection system (HIDS), which monitors the internal activities of a computing system and identifies malicious activities, including external actors or the misuse of internal resources or data.

On the one hand, a host intrusion detection system uses various data sources, including system logs, to identify the malicious activities in the targeted component. Several research efforts have been conducted in the realm of HIDS for critical control systems. On the other hand, NIDSs are mainly deployed between the ICS and enterprise networks to monitor network traffic. Due to the field-bus devices' limited memory and computing capability, executing other software on them is challenging. Consequently, implementing a host-based intrusion detection system is frequently challenging, which makes only a network-based implementation a practical option (Ortega-Fernandez et al., 2023).

NIDS and HIDS are evaluated according to their ability to identify attacks. Such an evaluation requires a comprehensive dataset. KDD-CUP99 (Tavallae et al., 2009a) and NSLKDD (Revathi and Malathi, 2013) are considered the oldest benchmark datasets that have been widely adopted for NIDS evaluation. However, according to several studies on NIDS evaluation Meena and Choudhary (2017), Bala and Nagpal (2019), and Su et al. (2020), these datasets do not provide an accurate representation of realistic output performance due to several factors. First, duplicate records in KDDCUP99 result in detection biases towards redundant records. Second, while the NSLKDD dataset is an improved version of the KDDCUP99 dataset and resolves the identified issues, including missing values and redundant records, this dataset does not reflect or represent modern attack environments.

Vulnerability assessment tools are challenging to apply for ICS systems due to their operational nature, being long-lived, and their distributed operational area. The ICS systems run 24 h a day to provide essential services, and the vulnerability scanning tools can halt the system process during the assessment. Also, no vulnerability benchmark datasets are available for ICSs. Therefore, this paper aims to create an ICS-LTU2022 vulnerability benchmark dataset to be used by cybersecurity researchers for vulnerability and risk analysis.

1.1. Motivation

ICS systems are a critical infrastructure component, including power plants, water treatment facilities, and transportation systems. Unfortunately, they were not initially designed without security, leading to many operating on outdated software and hardware. This gap in architecture leaves these systems vulnerable to various threats, both internal and external. Any cyber attack on an ICS system could have serious consequences, such as service disruptions, financial losses, and potential risks to human life. As the threat landscape for ICS evolves, new vulnerabilities are being discovered consistently. Therefore, a comprehensive vulnerability and risk assessment dataset is essential. Additionally, there is a lack of reporting incidents and vulnerability. Cyber incidents occur daily; while some are significant and others minor, the majority are never reported. Homeland Security and Government Affairs report highlighted that the lack of comprehensive data on ransomware attacks and the use of cryptocurrency for ransom payments in these attacks is due to under-reporting HSGAC (2021). There are several factors leading to underreporting, including fears related to competition, reputation concerns, the increased cost of reporting processes, possible financial penalties, the low level of organisational IS maturity, as well as burdensome regulatory compliance procedures Ahmad et al. (2012), Ruefle et al. (2014), Etzioni (2014), Humphrey (2017). Regulations such as the NIS Directive for critical infrastructure providers, the EU General Data Protection Regulation (GDPR), and the PSD2 Directive for financial institutions enforce strict incident reporting requirements for organisations (Housen-Couriel, 2018). Additionally, organisations may not report incidents due to concerns about their reputation. For

example, the oil and pipeline gas explosion incident in Russia caused a significant impact on the pipeline owner's reputation, jeopardising the confidence level of their internal and external stakeholders such as investors, employees, and customers Zardasti et al. (2017). Klahr et al. (2017) surveyed cyber security breaches and stated other reasons for not reporting incidents, such as businesses stating that "breach was not significant enough" (58%), that businesses were not aware of whom to report it to (16%) and that reporting "will not make a difference" (10%).

Moreover, vulnerabilities identified in the ICS components might be delayed in being reported to the NVD (Rytel et al., 2020). Therefore, vulnerabilities might be disclosed incompletely. Attackers might choose an alternative channel to disclose vulnerabilities until the affected component is patched. Consequently, vulnerabilities in the ICS systems might not be fully documented in the NVD. Fig. 1 shows the reporting process of ICS vulnerability. For instance, CVE-2020-26989 was assigned to stack overflow vulnerability. Siemens reports that this vulnerability affects the following products and versions: JT2Go: All versions before v13.1.0.1, and Teamcenter Visualisation: All versions before v13.1.0.1. The vulnerability description with CVE-ID and references is forwarded to MITRE NVD to rate the severity and impacts on confidentiality, integrity, and availability. So, the description has a list of vulnerable products. Subsequently, the vendor issues other advisories to be published in IC-US CERT, which publishes it. Hence, the NVD has not updated the remaining lists of vulnerable products.

A significant difference between ICS devices and typical information technology (IT) systems is that ICS devices are designed for reliability and safety. ICS devices should be able to operate for many years and remain resilient to external factors, such as electromagnetic interference. The devices are not built with security in mind because they are intended to be isolated from the Internet. However, Shodan (<https://www.shodan.io>) is exposing numerous visible ICS devices on the Internet. Furthermore, the emergence of Industry 4.0 has introduced the integration of IoT and cloud components into industrial systems, creating new avenues for potential attackers (Thomas et al., 2020a).

Shodan is a search engine that indexes banner pages instead of indexing web pages, including data indexing on HTTP, SSH, FTP, and SNMP services. Information returned includes IP address, organisation name, open ports and services, City and Country of origin, and Internet Service Provider name. Security researchers and analysts typically use it to identify vulnerable ICS components. Thus, it can be used as a defensive mechanism if used proactively. However, Shodan can be used as a malicious means of discovering attacks in critical infrastructure since it makes it feasible for an attacker to locate ICS, providing a varied pool of attack resources. Hence, an attacker can perform large-scale attacks such as Distributed Denial of Service (DDoS) by leveraging multitudes of vulnerable ICS devices. For example, some ICS web applications provide an HTTP 401 response, indicating that authorisation is required to access the web page. However, the default login, such as 'admin/admin' or 'admin/12345', is used as the login credentials for the targeted system, assuming that external users will never access the system (Bada and Pete, 2020). The adversary can look up these default credentials or if they exist within the banner returned by Shodan. Also, other systems employ an HTTP 200 response, in which a user can directly access the targeted ICS component. Most of the vulnerabilities listed for the HTTP 401 returning sites still apply, including using default usernames and passwords. However, a secondary login screen can offer an attacker further information about the targeted ICS components. One of the possible risk scenarios is PLC manipulation. Siemens PLCs S7-300/400 products use a proprietary S7Comm protocol for communication. Klick et al. (2015) published a malware called PLCinfect, which can inject malicious code into the existing logic code of a Siemens PLC. Those controllers are directly connected to the Internet via port 102 (Siemens S7comm protocol). An attacker can exploit Shodan's search capabilities to identify these exposed PLCs. Moreover, Snap7 is a multi-platform Ethernet communication suite

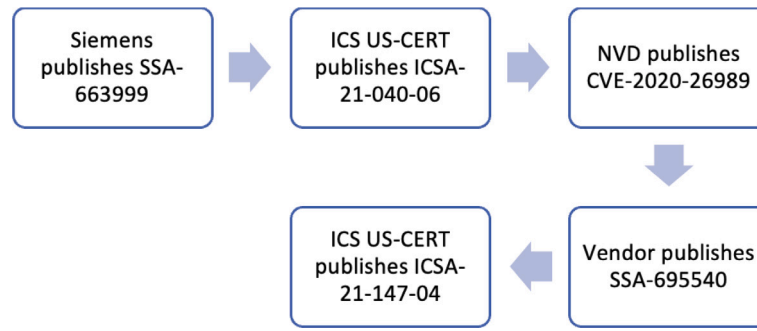


Fig. 1. ICS advisories publication process.

designed to interface natively with Siemens S7 PLCs. With the aid of Metasploit module auxiliary/admin/scada/simatic s7 300 command, a Siemens Simatic S7-300 PLC starts and stops (Beresford, 2011; Kant et al., 2020). The Metasploit module memory view.rb enables memory reading from an S7-300 PLC. Furthermore, a brute force attack tool was published by the SCADA Strangelove community to extract passwords for S7 PLCs (Kant et al., 2020).

Assessing ICS vulnerabilities is challenging due to their operational nature and ability to provide essential services 24/7. The existing vulnerability assessment tools can disrupt the operations of the ICS systems because they are intended to scan for threats in IT systems. The ICS systems run 24 h a day to provide essential services, and the vulnerability scanning tools can halt the system process during the assessment. In other words, active scanning tools have been known to cause malfunctions for many ICS systems due to the additional traffic and exploits combined with limited resources of ICS components (Stouffer et al., 2011). Thus, improving the security mechanisms in ICS networks is necessary. Recently, attempts have been made to leverage AI techniques in various cybersecurity applications (e.g., intrusion detection, prevention, and prediction systems). Developing intelligent security systems, including vulnerability and risk prediction, requires an ICS-related vulnerability dataset. Unlike the vulnerabilities of other computer systems, ICS vulnerabilities lack a public database (Igre et al., 2006). Although a few public vulnerability databases exist, such as the National Vulnerability Database (NVD) and Common Vulnerabilities and Exposures (CVE), they are not specified for ICSs. Therefore, there is an urgent need to create an ICS-related vulnerability dataset that can be used to build intelligent prediction systems for risk and vulnerability assessments.

1.2. Contributions

As research on ICS vulnerability datasets is limited, this study attempts to fill multiple gaps in the field of ICS cybersecurity research. It makes the following significant contribution: a recent vulnerability benchmark dataset contributing to the need for vulnerability analysis of ICSs. It provides a comprehensive collection of known vulnerabilities affecting ICSs, gathered from various sources and organisations. Table 5 illustrates the new data points introduced in the ICS-LTU2022 dataset that are not present in other datasets. Furthermore, Table 2 shows the research effort related to the creation of the IT/ICS datasets. None of the existing datasets can be used for top trend analysis in terms of ICS vulnerability since their creation purpose was intrusion detection. Additionally, it helps identify patterns and trends in vulnerabilities affecting ICS systems. Creating this dataset is a crucial step in enhancing the security and resilience of ICS systems, which are vital for critical infrastructure. Hence, our proposed ICS-LTU2022 dataset can be seen as secondary metadata for existing vulnerability data. The main use of this dataset is vulnerability assessment for risk evaluation in industrial control systems. The dataset will be made available for security researchers to evaluate their work on risk assessment.

1.3. Objectives

In this study, we created a vulnerabilities dataset to analyse cybersecurity issues and evaluate cybersecurity solutions for ICS systems. In this research, we limited the analysis to vulnerabilities with CVSS scores from 2016 to 2023 to ensure that severity assessments are based on the most current methodologies and criteria. CVSSv2 launched in 2007, and was widely adopted by vendors and enterprises as a common language to compare software vulnerabilities. However, version two also had significant issues to be addressed. Consequently, the 3.0 revision being released in 2015 Howland (2023). We attempted to identify the most vulnerable ICS components by answering the following question: *RQ1: What are the most vulnerable components within ICS networks?* A critical part of risk mitigation, threat awareness, compliance, resource allocation, and effective incident response is identifying vulnerable components in the ICS systems. It protects the critical infrastructure and ensures operational continuity while ensuring the security and integrity of industrial processes.

This paper also provides trend analysis and an understanding of vulnerability evolution over time. It answers the following question: *RQ2: Which year has seen the most vulnerabilities in ICS systems? and Why vulnerabilities are increasing despite Cybersecurity investments?* Understanding vulnerability trends helps industry experts develop secure systems, minimise the impact of current threats, and provide guidance for the research community on emerging security issues in ICSs.

RQ3: Which sector has the most ICS system vulnerabilities? Each organisational sector has unique characteristics, including data processing, technical equipment, supply chains, regulations, policies, and standards. For example, the healthcare sector depends on IT and medical equipment, whereas the energy sector depends on smart meters to process data. Therefore, they vary in vulnerabilities, impacts, and consequences. A successful exploit of a security vulnerability leads to either a power outage in a smart grid or a process disruption in critical manufacturing. Understanding the security vulnerabilities within a specific ICS component in an industrial sector helps identify proactive security measures.

RQ4: How common are the architectural weaknesses of ICSs based on risk density? Understanding vulnerability density paves the way for security researchers to determine the most common architectural weakness. *RQ5: What are the vendor-related vulnerabilities of ICS systems, and how does their risk density impact the overall security posture of the ICS systems?* Understanding vendor-related vulnerabilities helps industrial organisations effectively manage patches, as well as improve their policies, procedures, and standards.

This dataset will be made public for use in ICS security research. A description of the proposed dataset is provided in Section 4. We evaluated the effectiveness of the dataset in Section 8. Section 3 compares the characteristics of the existing ICS datasets and their limitations.

Table 1
Comparison between ICS intrusion detection datasets.

Dataset	Year	ICS vulnerabilities	Threat landscape	Organisational sectors	Targeted data				Attack scenario					# of labelled features	Ref.
					Field device data	Software data	IT Network data	ICS Network Data	Modification	Fabrication	Corruption	Interception	Interruption		
DARPA	1998	X	X	IT and computer systems	X	X	✓	X	X	X	X	✓	X	41	Labrotary (1999)
KDDCUP99	1999	X	X	IT and computer systems	X	X	✓	X	X	X	X	✓	✓	41	Newman (1999)
NSL-KDD	1999	X	X	IT and computer systems	X	X	✓	X	X	X	X	✓	✓	41	McHugh (2000)
Morris-1	2013		X	Power System	✓	X	X	X	✓	✓	X	X	X	128	Morris et al. (2011)
Morris-2	2014	X	X	Gas Pipeline	X	X	X	✓	✓	✓	X	X	✓	128	Beaver et al. (2013)
Morris-3	2014	X	X	Gas Pipeline and Water	X	X	X	✓	✓	✓	X	X	✓	128	Morris and Gao (2014)
Morris-4	2015	X	X	Gas Pipeline	X	X	X	✓	X	✓	X	X	✓	128	Morris et al. (2015)
UNSW-NB15	2015	X	X	IT and computer systems	X	X	✓	X	X	✓	X	✓	✓	49	Moustafa and Slay (2015)
SWaT	2016	X	X	Water systems	X	X	X	✓	X	✓	X	X	X	18	Qi et al. (2018)
Morris-5	2017	X	X	EMS	✓	X	X	X	X	✓	X	X	X	128	Morris et al. (2015)
Rodofile	2017	X	X	Mining Refinery	✓	X	X	✓	✓	✓	X	X	X	13	Rodofile et al. (2017)
WDT	2021	X	X	Water system	✓	X	X	✓	X	X	X	✓	✓	21 (Physical state variables) 14 (Network features)	Faramondi et al. (2021)
ICS-LTU2022	2022	✓	✓	Various sectors	✓	✓	✓	✓	✓	✓	✓	✓	✓	64	

2. Background

The industrial control systems are a collection of both hardware and software components designed to monitor the industrial processes locally and remotely. In this section, we cover an overview about the industrial control system including, ICS components, security architecture, vulnerabilities and threats.

2.1. ICS components

ICS components consist of hardware and software specifically designed for monitoring and controlling industrial processes, such as sensors, actuators, programmable logic controllers (PLCs), remote terminal units (RTUs), and Human–Machine Interfaces (HMIs). The hardware components involve control devices such as PLCs and RTUs that are used to manage and execute control logic in industrial processes. Control devices, including PLCs and RTUs, interact with sensors and actuators to monitor the physical processes based on predefined algorithms. The software components involve HMIs, SCADA software, firmware, and other embedded software in control devices. ICS network infrastructure includes communication protocols, such as (i.e. Modbus, PROFIBUS, DNP3, PROFINET, etc.) used for communication within the ICS environment. More information about the ICS communication protocols can be found in Alanazi et al. (2023). Additionally, web-based technologies are being integrated into ICS environments. This integration may include web applications for remote monitoring, data visualisation, and control of industrial processes. For example, web applications are being used to provide ICS enablers and operators with remote access to real-time process data, historical data, and control functionalities via web browsers or mobile devices. The web applications interact with underlying ICS components to perform industrial tasks. Instead, they serve as interfaces or gateways that enable human operators to interact with and monitor the underlying ICS infrastructure (ICS-CERT, 2016). However, introducing web applications into ICS environments makes ICS systems vulnerable to common web application vulnerabilities such as SQL injection, cross-site scripting (XSS), and bypass authentication. Therefore, securing web applications in ICS environments is crucial to maintaining security and resilience of industrial control systems.

2.2. ICS security architecture

The structural design of an ICS system starts with remote terminal units (RTUs) and programmable logic controllers (PLCs), which are microprocessors that communicate and interact with field devices (e.g., sensors, actuators, pumps, and valves). Human–machine interface (HMI) software facilitates interaction with field devices. Enterprise networks have been directly connected to industrial processes. Fig. 2 depicts the Purdue Model that is designed for data flow in computer-integrated manufacturing. The Purdue model is a framework employed to organise and visualise the architecture of industrial control systems and operational technology networks. Purdue University proposed it in the 80s to address the unique challenges of securing and managing ICS environments (Williams et al., 1989). It consists of six levels. The physical layer includes field devices, such as sensors and actuators, which monitor and collect data from their operational environments. The SCADA master then analyses the data collected by the field devices. SCADA systems rely on the PLC and RTU to make critical decisions. It is crucial to maintain the integrity of data transmitted from the field devices; any invalid data can significantly impact the functionality of these devices. The current versions of master terminal units (MTUs) are directly connected to the internet, allowing the remote control of field devices. A demilitarised zone enhances (DMZ) and segregates devices, such as computers and servers, on the opposite side of the firewall. The Enterprise Level represents the interface between the operational technology environment and IT infrastructure.

2.3. Comparison between ICS and IT attacks

Adopting commercial off-the-shelf (COTS) increases network optimisation and cost-efficiency by reducing the cost of heavy equipment and proprietary communication protocols. Nonetheless, this adoption of COTS software into ICS networks introduces a broad spectrum of cyber threats to critical infrastructure (Sajid et al., 2016). Hence, ICS systems can be exploited and attacked using the same techniques employed on COTS software on IT networks (Stouffer et al., 2011). Also, a growing number of threats have been directed towards critical infrastructure due to the move from an ICS isolated environment into organisations' networks connected to the public internet (Pliatsios et al., 2020; Alanazi et al., 2023). Previously, several IT vulnerabilities and exploits did not work in air-gapped ICS environments (Bakeui et al., 2021; Alanazi et al., 2023). Several vulnerabilities within ICS components exist in the current ICS architecture, and these security

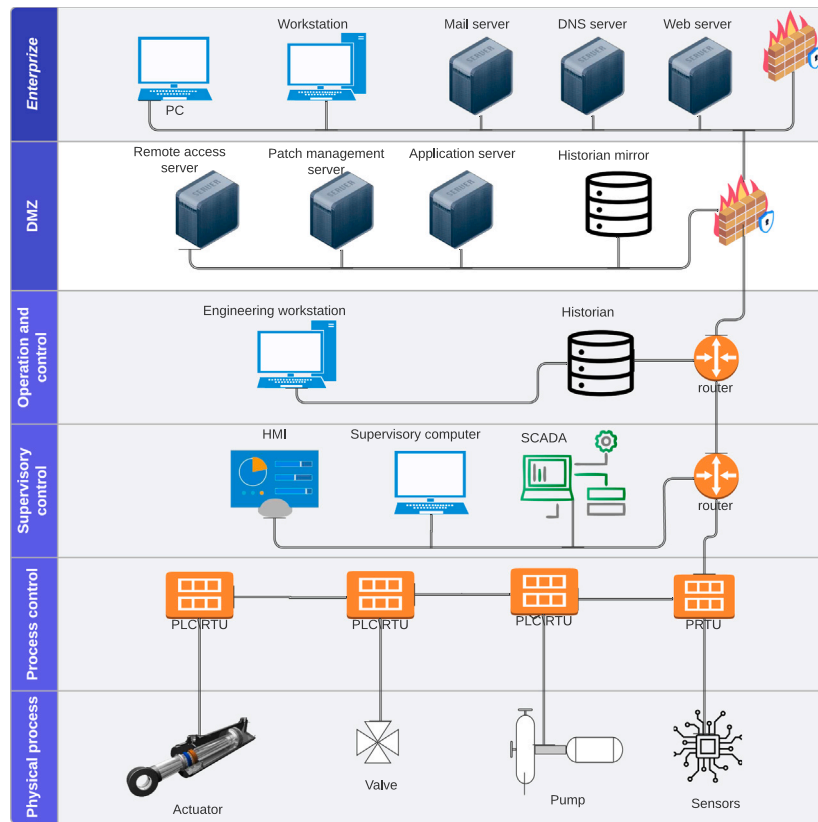


Fig. 2. Illustration of ICS security architecture.

holes can be exploited remotely. For example, PLC CJ/CS is vulnerable to device configuration attacks due to a lack of authentication and improper access control. While OT vulnerabilities affect the security and functionality of industrial control systems, IT vulnerabilities affect the security of computer systems, networks, and software applications. A successful exploit of OT vulnerabilities causes disruptions in critical infrastructure operations, safety hazards, and potential damage to physical assets. IT and OT vulnerabilities can cause unauthorised access to sensitive information, data breaches, financial losses, and disruptions to business operations (Conklin, 2016). However, the impact of OT vulnerabilities can have far-reaching consequences for industrial processes and public safety.

MITRE corporation has released the ICS MITRE ATT&CK matrix Which is a comprehensive framework tailored with the ICS systems MITRE (2024). It consists of a detailed matrix of techniques and methods used by malicious actors to penetrate the industrial control system. With Havex, adversaries can deploy additional payloads and functionality while gathering sensitive data about ICSs. Mapping Havex with MITRE ATT&CK Matrix for Enterprise and ICS, it is observed that adversaries employ different tactics and methodologies in each environment.

Havex employed malicious software to inject and compromise websites in the enterprise network, distributing the malicious payloads to end users. The malware gathers sensitive information about the computer system and establishes a backdoor for remote control by the attackers. The primary purposes of attacking enterprise networks were to gather information about available drivers, default web browsers, user credentials, and running processes, Fig. 3.

In ICS networks, Havex is executed in three ways: through trojanized software installers, spear phishing, or watering hole attacks. It uses the OPC protocol to communicate with the command and control (C2) server. Havex then collects detailed information about ICS devices, operational parameters, and network configurations to conduct further attacks against the ICS system, Fig. 4.

Therefore, cyberattacks against both IT and ICS can be executed remotely, locally, or adjacently. In traditional IT environments, cyber incidents can corrupt digital data, compromise sensitive information, destroy data, and disrupt business applications. In ICS environments, cyberattacks can damage assets, impact the environment, and threaten human lives in extreme cases. Furthermore, adversary attack research and exploit kits are well-known, publicly available and scalable to general IT networks. Adversaries often prefer to exploit IT vulnerabilities that do not require authentication remotely and vulnerabilities that affect confidentiality, integrity, and availability components (Alanazi et al., 2023).

2.4. Comparison between OT, ICS and SCADA

The majority of Industrial Control Systems (ICSs) may be categorised as either continuous process control systems, which are typically supervised by programmable logic controllers (PLCs), or discrete process control systems (DPC), which may use a PLC or another type of batch process control device. Industrial control systems (ICS) are typically managed through Supervisory Control and Data Acquisition (SCADA) systems. These systems offer a graphical user interface that enables operators to easily monitor a system's status, receive alarms for any abnormal operation, and adjust the controlled process. SCADA systems display the process being controlled and provide access to control functions (Colbert and Kott, 2016). OT, ICS, and SCADA security have overlapping functions in protecting industrial processes and critical infrastructure. OT security protects the systems that manage, supervise, and control manufacturing operations, particularly those increasingly connected to and integrated with information technology systems. In contrast, ICS security focuses more on the systems that directly control industrial processes and equipment. These systems are crucial for the operation of several industries, ranging from power production to manufacturing. ICS security is of utmost importance due to the severe

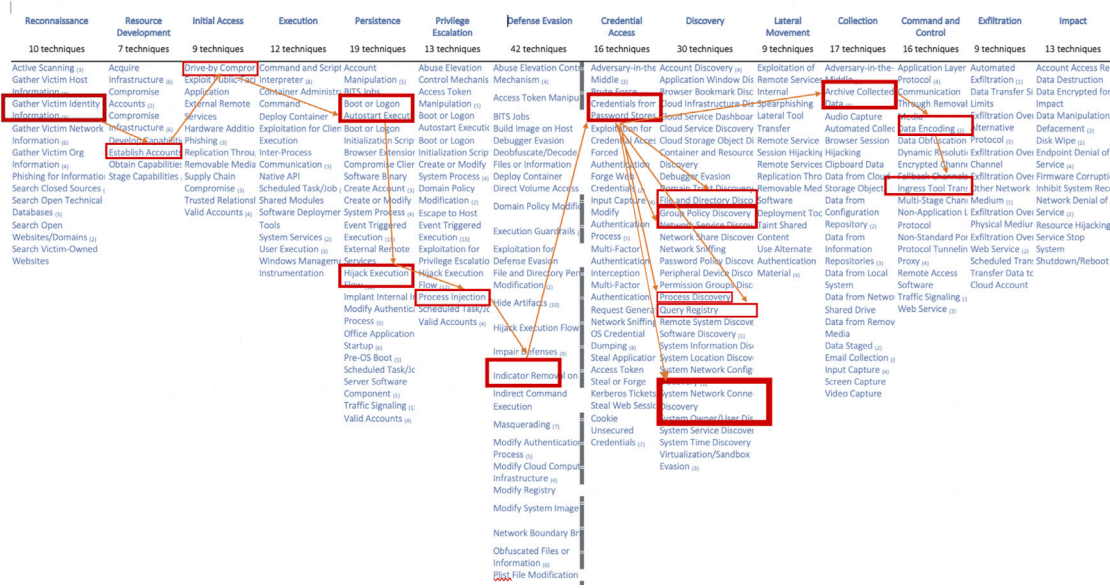


Fig. 3. Mapping Havex to Mitre Att&ck matrix for Enterprise.

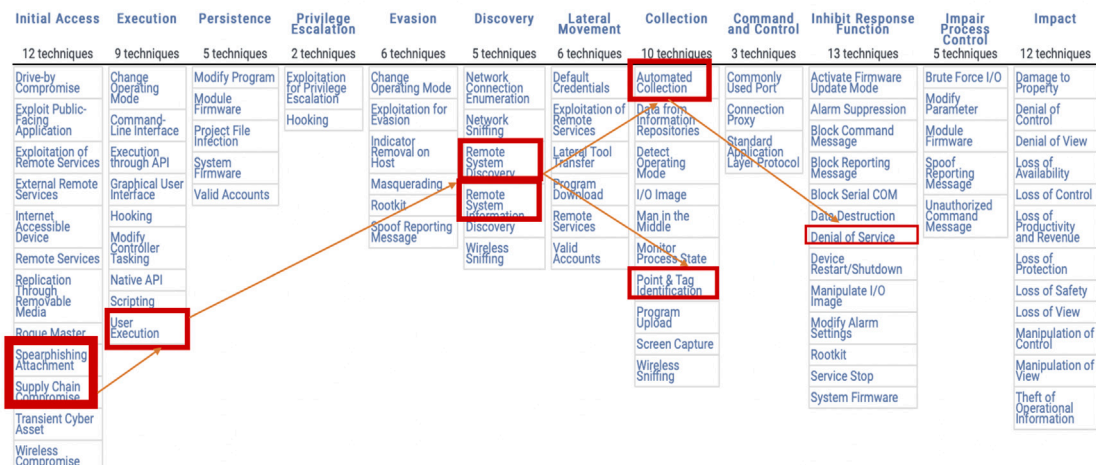


Fig. 4. Mapping Havex to Mitre Att&ck matrix for Enterprise.

consequences that breaches might cause. Each component within an ICS network, ranging from PLCs to HMIs, requires appropriate security measures to mitigate the various cyber threats they face (Ali et al., 2018). SCADA security is a subset of ICS security that focuses on protecting systems utilised for collecting real-time data, controlling processes, and monitoring operations in different industrial environments. The industrial SCADA system is intrinsically linked to public safety and the uninterrupted provision of services. This requires a comprehensive strategy that combines governance, risk management, and compliance controls with technological and physical security measures (Ali et al., 2018).

3. Related work

The NVD has been used by several researchers to analyse the frequency and distribution of vulnerabilities. In Christey and Martin (2007), vulnerabilities between 2001 and 2006 were examined by comparing OS vendors with non-OS vendors and open-source with closed-source code. Additionally, according to a study on vulnerability analysis conducted by Yadav and Paul (2021), only fifteen ICS vulnerabilities were reported between 2000–2007. Miller and Rowe

(2012) analysed ICS attacks in the Repository of Industrial Security Incidents (RISI) database based on the originating sector, implementation method, and target sector. According to their study, the RISI database has not been updated since 2014. In this section, we first compare IDS attack datasets and vulnerability datasets in terms of purposes, focus, content, usage, and examples. Subsequently, we review existing IDS attack datasets and vulnerability datasets in the context of industrial control systems.

3.1. Comparison of attack dataset and vulnerability dataset

While IDS datasets play a vital role in detecting cyber-attacks by analysing the network traffic patterns, vulnerability datasets offer insights into the nature of vulnerabilities present in the computation logic of systems, aiding in the efficient management of systems related vulnerabilities. Therefore, it is essential to distinguish between dataset related to vulnerabilities and other dataset related to intrusion detection systems (IDS). For vulnerability database, we revised 25 papers to identify the primary goal for the vulnerability dataset. The primary goals are outlined as follows:

- Analytical purposes: 52% of the selected papers contributed to trend analysis of the most recent ICS related vulnerabilities (Neuhaus and Zimmermann, 2010; Andreeva et al., 2016; McLaughlin et al., 2016a; Williams et al., 2018; Yadav and Paul, 2021; Wu et al., 2021; Miller et al., 2021; Sindhwa et al., 2022), quality assessment of vulnerability database (Anwar et al., 2022; Kuehn et al., 2021), and vulnerability distribution (Pham and Dang, 2018; Yadav and Paul, 2021; Blinowski et al., 2021).
- Creation purposes: 20% of the selected papers contributed to vulnerability dataset creation by extracting information from publicly available sources (Gkortzis et al., 2018; Jimenez et al., 2018; Thomas et al., 2020b; Ponta et al., 2019; Bhandari et al., 2021; Alsmadi et al., 2022).
- Vulnerability prediction: 16% of the selected paper contributed to vulnerability prediction by adopting publicly available vulnerability datasets (Thomas and Chothia, 2020; Ur-Rehman et al., 2020; Williams et al., 2020; Nair et al., 2022).
- Vulnerability classification: 12% of the selected papers contributed to vulnerability categorisation by adopting multiple vulnerability datasets (Thomas and Chothia, 2020).

For IDS datasets, we revised the fifteen IDS datasets papers to identify the purposes of creating the IDS datasets (McHugh, 2000; Tavallae et al., 2009a; Morris et al., 2015; Morris and Gao, 2014; Zohrevand et al., 2016; Morris et al., 2015; Moustafa and Slay, 2015; Wermann et al., 2016; Meena and Choudhary, 2017; Morris et al., 2011; Faramondi et al., 2021). The primary goal of creating these datasets is to monitor and detect malicious network traffic. Furthermore, remarkable research efforts by adopting IDS datasets contributed to the following:

- Dataset evaluation: Where the primary goal of the research is to evaluate the dataset themselves (Gharib et al., 2016; Karatas et al., 2020; Zaman et al., 2023).
- Intrusion detection and prevention system evaluation: The main purpose is to evaluate the performance of a proposed detection model on one or multiple IDS dataset (Mubarak et al., 2021; Jabez and Muthukumar, 2015; Golrang et al., 2020; Pooja and Shrinivasacharya, 2021).
- Analytical purposes: Examine and analyse cyberattacks against critical control systems by adopting one or multiple IDS datasets (Ghurab et al., 2021).
- Dataset creation: The primary goal is to create a dataset for intrusion detection system by extracting several features from network traffic or system logs (Morris et al., 2015; Moustafa and Slay, 2015; Wermann et al., 2016; Zohrevand et al., 2016; Morris et al., 2011; Meena and Choudhary, 2017; Faramondi et al., 2021).

Both IDS and vulnerability datasets can be used for analytical and creative purposes. The IDS dataset contains information about network traffic (e.g., timestamps, payload content, port numbers, etc.), while the vulnerability dataset offers insightful information regarding identified vulnerabilities in the computational logic of the control system (e.g., affected product, severity, CVSS score, impact on CIA, vulnerability type, etc.). The vulnerability dataset can be used for efficient vulnerability assessment and patch management. In contrast, datasets related to IDS attacks are used for training, testing, and evaluating intrusion detection systems. Vulnerability datasets typically focus on known security weaknesses in software or control systems, whereas IDS datasets focus on detecting malicious activities. Vulnerability datasets can be used as inputs to develop vulnerability management platforms, whereas datasets related to IDS can be used to evaluate network defender tools.

3.2. Existing vulnerability dataset

To best of our knowledge, industrial controls systems lack comprehensive publicly available vulnerability dataset. However, there

are some relevant databases that involve vulnerabilities tailored for industrial control system. Firstly, national vulnerability database (NVD) dataset is a vulnerability indexing database managed by National Institute for Standards and Technology (NIST) to provide comprehensive and authoritative information about IT security vulnerability. It provides a searchable interface and data feeds for the severity, impact, and nature of the identified vulnerabilities. Each vulnerability is assigned with Common Vulnerability Scoring System (CVSS) score and its impact on integrity, availability and confidentiality. It is fully synchronised with Common vulnerability exposures (CVE), and common weaknesses enumeration which are maintained by MITRE. While these two databases are utilised interchangeably, they are essentially distinct. CVE is a list of vulnerability entries. Nevertheless, NVD is a more powerful database based on and fully synced with the CVE list, ensuring that any revisions to the CVE list are reflected in the NVD. However, NVD Lacks direct association with vulnerability details, requiring users to rely on additional sources for comprehensive information. The industrial control systems cyber emergency response team (ICS-CERT) releases advisories regarding vulnerabilities in the ICS systems. Although these advisories are not be considered as a dataset, vulnerability information can be collected manually. It involves NVD data, in addition to the industrial critical infrastructure and the region deployed the affected product. Exploit Database (Exploit-DB) is a widely used resource for finding and downloading security exploits. It is different from CVE since it provides its own indexing system. It also provides detailed exploit code, descriptions, and information about vulnerable software versions. It focuses on providing demonstration on how vulnerabilities can be exploited. However, quality and reliability of exploits may vary. The open-sourced vulnerability database (OSVDB) was an open-source project aimed to collect information about security vulnerabilities. It provides a comprehensive database of vulnerabilities from various sources, including vulnerability disclosures, security advisories, and public reports. OSVDB aimed to be a valuable resource for security professionals, researchers, and organisations seeking information about known vulnerabilities to improve their security posture. It provides detailed information about each vulnerability, including descriptions, references, affected products, and potential impact. However, the OSVDB website and database have been inaccessible since 2016. The Open worldwide application security project (OWASP) is a nonprofit platform that used to improve the security of software. It reflects emerging web application vulnerabilities.

3.3. Existing ICS attack datasets

During the 1999 DARPA Intrusion Detection Evaluation event, training data were provided in the first, second, and third weeks, and test data were provided in the fourth and fifth weeks (Labrotary, 1999; McHugh, 2000). A training dataset consisted of normal traffic in the first and third weeks and of labelled attacks in the second week. The MIT Lincoln Laboratory used a subset of the DARPA dataset to extract features, resulting in the KDDCUP99 dataset (Newman, 1999; Lee et al., 1999). There are 41 features in this dataset, grouped into three categories: basic features, content features, and traffic features. The features are computed for normal and attack records, including five types of attacks: probe, DoS, remote to local (R2L), user to remote (U2R), and data attacks. One disadvantage of the DARPA dataset is that it was recorded on an isolated network that was not connected to the internet. Additionally, there was a lack of correlation between the training and testing datasets for R2L and U2R attacks, which resulted in poor performance for some IDSs. It follows that most pattern recognition and ML algorithms, except for anomaly detectors that learn only from normal data, will be ineffective at detecting R2L and U2R attacks.

The KDD-CUP 99 dataset is used by security analysts to test NIDS (Revathi and Malathi, 2013). This dataset contains hybrid attacks that target network traffic, such as reconnaissance, worms, exploits, fuzzers,

and DoS attacks. However, the training set includes a significant number of duplicates. To address this, NSL-KDD is an improved version of KDD-CUP 99 that eliminates the duplicates in KDD-CUP 99 (Revathi and Malathi, 2013). Nevertheless, it is outdated and has limited attack variety, as it does not capture modern threats.

Morris et al. (2011) released five datasets related to power, gas, and water systems. The datasets consist of field device data, logs, and network data. The Morris-1 dataset includes 37 event scenarios for power systems, network data, and normal and abnormal events in field devices (Wermann et al., 2016). However, Morris-1 does not involve network data (i.e. communication protocols). Modbus communication protocols between the human-machine interface (HMI) and control devices in the gas pipeline testbed are included in the Morris-2, Morris-3, and Morris-4 datasets (Beaver et al., 2013; Morris and Gao, 2014; Morris et al., 2015). Compared with the other Morris datasets, Morris-5 involves data collected from a realistic energy management system over a month.

The University of New South Wales released the UNSW-NB15 dataset for research purposes, specifically for evaluating the performance of intrusion detection systems and conducting cybersecurity research (Moustafa and Slay, 2015). It provides a set of network traffic scenarios, including reconnaissance, worms, exploits, fuzzers, and DoS attacks. It is publicly available for cybersecurity researchers to evaluate network intrusion detection systems.

The water supply system (SWaT) dataset consists of log files of multiple features, such as temperature, water, inflow, and outflow (Qi et al., 2018). The dataset includes both normal operation data and data with simulated cyberattacks, such as DoS and spoofing attacks. The SWaT dataset is being used by cybersecurity researchers to enhance defensive mechanisms. However, the dataset is exclusive to water supply systems, and the attack scenarios it simulates do not fully capture cybersecurity threats faced by other industries. Additionally, as a synthetic dataset, SWaT does not capture real-world network traffic over an extended period. Consequently, it may not encompass all possible scenarios and events that could occur in a water treatment plant over an extended period.

A water distribution testbed (WDT), as introduced by Faramondi et al. (2021), was employed to create an intrusion detection system for ICSs. The proposed dataset includes both system state variables and network data to reveal the attack consequences on physical processes and networks. This dataset encompasses both system state variables and network data, facilitating the exploration of the impact of attacks on both physical processes and network systems. Table 1 highlights the key characteristics of the existing intrusion detection systems.

Table 2 the DARPA dataset is comprehensive but needs extensive preprocessing and specific tools for formats such as PCAP, reducing its accessibility. The KDDCUP99 dataset, originating from DARPA, has noise and outdated data and requires moderate preprocessing. The NSL-KDD dataset enhances the KDDCUP99 dataset but does not include several modern attack vectors. The Morris datasets consist of distinct attack scenarios and a combination of different formats, which need moderate preparation and specialised tools. The UNSW-NB15 dataset provides up-to-date and comprehensive information, although it can be large and requires rigorous control. The SWaT dataset is very relevant to Industrial Control Systems, although, similar to other datasets, it could be extensive in size. While readily available, the Rodofile and WDT datasets often need some preprocessing and may exhibit variations in data quality. Generally, these datasets provide excellent insights but frequently need extensive preprocessing. They can also be used for intrusion detection, while the ICS-LTU2022 can be used for vulnerability and risk assessment.

3.4. ICS-related protocols in the public dataset

Most existing ICS datasets involve Modbus protocols (i.e. Modbus/RTU in Morris-2, Modbus TCP in UNSW-NB 15, WDT, and other

datasets). The most common industrial protocol, Ethernet/IP, is used in the SWaT datasets. Rodofile et al. (2017) proposed a framework for ICS cyberattack dataset generation. The proposed framework targets DNP3 protocols because it is predominantly used in the power transmission network. The proposed network dataset in Faramondi et al. (2021) involves Modbus TCP/IP function codes and values. Table 3 shows the ICS-related protocols in the publicly available dataset.

3.5. Existing vulnerability prediction models

Per the findings of Almukaynizi et al. (2017), they developed a predictive model for cyber vulnerabilities to assess the likelihood of a vulnerability being exploited. They gathered data from various sources, including the NVD, Exploit DB, Zero Day Initiative, and forums on the dark and deep web. They amalgamated the Symantec antivirus and IDS signatures to create a ground truth dataset. Among the models they tested, the TF-IDF model applied to text data exhibited the highest accuracy. Although their most successful model achieved a commendable true positive rate and a low false positive rate (90% and 13%, respectively), the overall F1 score was only 0.40, indicating potential overfitting for the majority class (Hoque et al., 2021).

Tavabi et al. (2018) introduced an alternative vulnerability exploitation prediction model called Dark Embed, based on word embedding techniques. The authors collected the text corpus from discussions and posts related to vulnerabilities on the dark web. They used the Symantec antivirus, IDS attack signatures, CVSS scoring, and vulnerability data from Exploit DB to validate their prediction model. The prediction model achieved an F1 score of 0.74. Nevertheless, the authors did not detail the performance metrics, such as recall, accuracy, and precision.

Edkrantz and Said (2015) used an SVM classifier to predict vulnerability exploitation based on commercial datasets from Recorded Future and utilised NVD datasets as the feature sets and Exploit DB as the ground truth. The most accurate model with the LibSVM algorithm achieved 0.83 accuracy, 0.82 recall, and a 0.83 F1 score, as well as the most accurate overall performance.

Reinthal et al. (2018) introduced two models for predicting vulnerability exploitation: one characterised as the naive model and the other as the realistic model. An extended period was used to collect NVD and web data. The main problem with naive models is that data collection continues even after exploitation. In other words, information about the future will be 'leaked' into the past after that event. Thus, it is impossible to make accurate predictions about the future using the naive model. Alternatively, the authors developed a realistic model that limits aggregation to a cut-off time equal to the median number of days between the publication of the NVD and Exploit DB. Despite using Xgboost, a supervised ML algorithm, their best model (realistic) achieved low values of precision of 0.578, recall of 0.440, and F1 of 0.511.

Zhang et al. (2011) introduced a new concept known as time to next vulnerability (TTNV) for assessing software applications. They conducted experiments utilising various classification algorithms to predict TTNV in software applications, such as the Linux kernel, Microsoft Windows, Internet Explorer, and Mozilla. They used time and version attributes from the NVD dataset as features. They concluded that effective prediction models could not be constructed based on the available data in the NVD. Remarkably, their best model applied to the Linux kernel resulted in relatively low accuracy of 61.8%, a false positive rate of 59.5%, and a true positive rate of 65.8%.

Bozorgi et al. (2010) developed a linear SVM prediction model to predict vulnerability exploitation within a specific timeframe. They used data from the NVD, the Open Sourced Vulnerability Database, Exploit DB, and private datasets. Their study employed two classifier models: one for offline prediction and another for simulated online prediction. The accuracy of the offline model was 0.89, while the simulated online model achieved an accuracy of 0.51 within a seven-day exploitation probability timeframe.

Table 2
Summary analysis of the ICS-LTU2022 datasets and existing datasets.

Dimension	ICS-LTU2022	DARPA	KDDCUP99	NSL-KDD	Morris (1-5)	UNSW-NB15	SWaT	Rodofile	WDT
Coverage and scope	ICS vulnerabilities	IT Network traffic data for cybersecurity research	Network intrusion detection	Improved version of KDDCUP99, removing redundant records	specific network intrusion scenarios	Contains modern network traffic with labeled attacks and normal traffic.	Focuses on industrial control systems (ICS) attack data.	Contains real network traffic data.	Specific water system traffic.
		Includes various types of network attacks.	Contains labeled attacks and normal traffic (4 categories).	Contains labeled attacks and normal traffic	Contains labeled data for different attack types	Includes more recent attack vectors and techniques (9 categories)	includes both normal and attack scenarios on a water testbed	Focused on specific intrusion detection scenarios.	encompasses both physical and network data were acquired from a hardware-in-the-loop Water Distribution Testbed (WDT)
Timeliness	Annually updated with recent SCADA vulnerabilities.	1998	1999	1999	Varies with each dataset version	2015	2016	2017	2021
Format	XLSX/CSV structured with clear column headers	Mixed formats, often requires preprocessing	CSV format, often requires preprocessing	Improved format over KDDCUP99	Mixed formats, may require preprocessing	CSV format, structured and detailed	CSV format, structured for ICS research	CSV format, often requires preprocessing	Csv format for the physical dataset and pcap file for network data, often requires preprocessing.
Usability	Vulnerability analysis and risk assessment	Intrusion detection in computer networks	Intrusion detection in computer networks	Intrusion detection in computer networks	Varies with each dataset version	Intrusion detection in computer networks	Intrusion detection in water systems	Intrusion detection in computer networks	Intrusion detection in water systems
Accessibility	Minimal	Publicly available but may require specialized tools for some formats	Publicly available but may require preprocessing	Publicly available and ready to use	Publicly available but may require preprocessing	Publicly available and ready to use	Publicly available and ready to use	Publicly available but may require preprocessing	Publicly available and ready to use

Table 3
ICS-related protocols in the public dataset.

Dataset	Modbus	PROFINET	DNP3	PROFINET
Morris-1	✓	–	–	–
Morris-2	✓	✗	✗	✗
Morris-3	✓	✗	✗	✗
Morris-4	✓	✗	✗	✗
Morris-5	–	–	–	–
UNSW-NB15	✓	✗	✗	✗
SWaT	✓	✗	✗	✓
Rodofile	✗	✗	✓	✗
WDT	✓	✗	✗	✗

(✓) = Yes, (✗) = No, (–) = Not given

3.6. Existing host based intrusion detection systems (HIDS)

Carcano et al. (2011) proposed a specification-based approach for detecting anomalies using process variables. The authors designed a formal modelling language to describe the state of the physical system. The authors designed a formal modelling language to describe the state of the physical system. They have also created a parametric measure that calculates the distance between a given state and the set of critical states. It helps to keep track of the system's evolution until it reaches the set of predefined critical states. A host-based attack detection and automated attack response modules were presented by Cárdenas et al. (2011). The authors employed a linear model to predict the output of the physical system based on the control input sequence. The anomaly behaviour was detected using a non-parametric cumulative sum statistic by comparing the expected outputs with the received signals. Hadžiosmanović et al. (2014) proposed a variable-specific prediction models using process variables to detect process control attacks by passively monitoring the plant activities and then extracting variables updates from the network. The extracted values then compared to predicted values that being computed from a learning period using autoregressive model. Almalawi et al. (2014) proposed

two anomaly detection techniques for integrity attacks against the SCADA system. Their proposed approach involves the automatic identification of consistent and inconsistent states of unlabelled SCADA data by assigning an inconsistency score to each observation using the density factor for the k-nearest neighbours of the observation. They then extract proximity-based detection rules from the identified states to detect inconsistent states in an automated manner. Bulle et al. (2020) proposed a host-based intrusion detection model for SCADA systems through OS diversity means. It consists of OS Behaviour Classification and OS Pool-Selector to increase the intrusion detection capability to detect further attacks. The authors considers their HIDS as an event represented as a set of OS-related usage metrics in a given time-window analysis, e.g., CPU usage in the last 10-s interval. The time window is classified by an ML model to identify anomalous behaviour. The event to be classified is sent by the OS Pool-Selector module, which evaluates the current environment behaviour for selecting the most reliable OS. The OS Pool-Selector module assesses whether the current OS SCADA front-end is appropriate for detecting new intrusion attempts. It employs an evaluator to identify unreliable behaviour, such as low confidence in ML classification for current events. Unreliable behaviour indicates intrusion attempts that the current SCADA OS front-end cannot detect, leading to a switch to another OS for improved system accuracy and reliability.

3.7. Limitations of existing models and datasets

There are limitations associated with the KDD99 dataset. The dataset is extensive, which causes a significant increase in the computational costs of IDSs. To tackle this issue, only 10% of the dataset is used. The KDD-99 record contains duplicates and redundant data. As a result, the learning process is challenging and may negatively impact a system (Tavallaee et al., 2009b). An enhanced version of KDD99 is available, known as NSL-KDD, that eliminates duplicate records (Meena and Choudhary, 2017). However, the current IC architecture is not compatible with KD99 and NSL-KDD, since it does not reflect current ICS attack scenarios. Moreover, DARPA recorded the data offline on

an isolated network (McHugh, 2000). In most cases, internet traffic consists of a considerable amount of anomalous traffic that is not caused by malicious behaviour. Therefore, trained algorithms will generate a significant number of false alarms. Also, there is no correlation between the training and testing datasets for R2L and U2R attacks. Hence, pattern recognition and ML algorithms cannot detect anomalous behaviour, except for anomaly detectors that use normal data. There are several features in the SWaT dataset, including temperature, water, inflow, and outflow (Zohrevand et al., 2016). However, the SWaT dataset is outdated, since it has not been updated since 2014. A specific ICS dataset should be considered both for vulnerabilities and attacks. In addition, all areas of ICS applications should be included in the dataset. More importantly, none of the existing datasets can generate a threat landscape for risk assessment purposes. Table 1 compares the existing datasets related to ICSs and critical infrastructure.

The overall performance metrics of an effective exploitability prediction model should be effective in the following three dimensions: accuracy, precision, and recall. In the current research on vulnerability exploitation prediction models, only Edkrantz and Said (2015) has shown good performance scores for accuracy, recall, and F1. Their model showed the highest performance scores for accuracy, recall, and F1 at 0.83, 0.82, and 0.83, respectively. Since this model was developed in 2015, it has not yet been tested with recent NVD data. Also, the existing prediction models are not valid for ICS, since these models were proposed for computer and IT systems. The existing imbalance between classes still needs to be addressed. Most existing exploitability prediction models have good accuracy but poor precision, recall, and F1 performance. A model with high accuracy but poor precision or recall indicates that it has been overfitted to the majority class. It has failed to resolve the class imbalance in the target class, since the number of exploited vulnerabilities is far less than unexploited vulnerabilities (Hoque et al., 2021). The ongoing research aims to mitigate the existing class imbalance through the utilisation of synthetic data, resampling methodologies, and algorithmic techniques. This approach is preferred over the development of a cost function that excludes artificial data resampling. Despite improving model performance to some extent, these approaches fail to effectively tackle the underlying cause of class imbalance. As a result, the dominant class models are overfitted.

4. ICS-LTU2022 dataset creation

A number of authoritative sources publish ICS vulnerabilities, including national vulnerability database (NVD), vendor advisories, CVE, and Industrial Control Systems Cyber Emergency Response Team (ICS US-CERT) advisories. As vendor advisories vary in terms of detail, format, and accessibility, the use of vendor advisories alone is also not appropriate for performing such an analysis (Thomas and Chothia, 2020). In other words, Scaling this approach is challenging because it is distributed in different formats, and a significant number of them exist. For example, Siemens ProductCERT does not provide an application programming interface (API) (Empl et al., 2024). Alternatively, they provide an Atom feed that allows querying CSAF security advisories based on the SSA ID, CVE, title, sector, product, or tags. Consequently, manual effort would be required to collect vulnerability information from vendor's advisories. Some major manufacturers have started distributing their advisories in Common Security Advise Framework (CSAF) format, a JSON file with standard fields that simplify collecting vulnerability information from vendors' advisories. Although this standard offers acceptable data consistency, larger suppliers utilise it differently, while smaller vendors never use it.

4.1. Justifications for using NVD as a primary data source

The NVD accommodates CWE, which is synchronised with it. Additionally, the NVD contains all the vulnerabilities related to ICS products. They were assigned by either the vendor or the CISA ICS-CERT. The CISA ICS-CERT accommodates inclusive information about ICS vulnerabilities fully synchronised with CVE, the NVD, and CWE. It provides information about affected ICS products and lists the industries and countries that deploy the affected ICS products. The NVD database is updated whenever a new vulnerability is added to the CVE dictionary. Despite the disclosure delays, NVD is considered a comprehensive vulnerability database. According to Rodriguez et al. (2018), the delays in NVD vulnerability disclosure are to provide a detailed analysis concerning its efficiency, which is helpful for developers and manufacturers. In other words, analysts provide additional vulnerability information within two days of the vulnerability being added to the CVE dictionary. Therefore, the disclosure of NVD vulnerabilities is delayed by two days to allow the provision of a comprehensive analysis for vulnerability that is useful for developers and manufacturers.

However, NVD itself is not efficient in conducting vulnerability analysis. Certain aspects of the data are missing in NVD, and they are essential for one of the primary use cases of this dataset, which is vulnerability assessment for risk evaluation in industrial control systems. For example, the missing aspects include the potential consequences of a successful exploit against ICS systems (e.g., memory corruption, information exposure, service disruption), vendors, affected products within a specific infrastructure, and the geographical areas where the affected products are deployed. Identifying the industrial sectors and geographical areas is crucial to determining the correlation coefficient between different regions and the types of identified ICS vulnerabilities.

In our research, the industrial sector and geographical area are crucial to identify the correlation between areas of the world and types of the identified ICS vulnerabilities, which NVD fails to cover these aspects. As ICS US-CERT is the only source that collects industrial data and identifies vulnerabilities across several critical infrastructures, we utilised this source to manually gather data regarding industrial sectors and their geographical distribution worldwide. Therefore, we integrate this information with the ICS vulnerability data that being extracted from the NVD database. We also extracted potential consequences of a successful exploit by retrieving them from the description in NVD entries using R studio.

This section of the paper illustrates the methodology for constructing the ICS vulnerabilities. Fig. 5 depicts the construction process of the ICS vulnerabilities, as follows:

- We referred to NVD, and the ICS-CERT as primary resources to unify our proposed dataset.
- We obtained a JSON file from the NVD website (<https://nvd.nist.gov/vuln/data-feeds>) to identify ICS-related vulnerabilities. The JSON feeds the included previous and new vulnerabilities databases in JSON format.
- We then extracted the information from that JSON file using a power query in Microsoft Excel.
- We filtered all the vulnerabilities assigned by the US-CERT. Finally, we sorted the ICS vulnerabilities using the keywords SCADA, ICS-CERT, HMI, PLC, RTU, Historian, Siemens, Omron, Rockwell Automation, etc.

Limiting our analysis to vulnerabilities with CVSS scores from 2016 to 2023 ensures that severity assessments are based on the most current methodologies and criteria. The cybersecurity threat landscape continuously evolves as new vulnerabilities are identified, regularly subjecting it to increasing threats. We also focus on vulnerabilities from the previous eight years to establish the most significant threat. The duration selected indicates today's challenges and ICS's most recent software security weaknesses. Modern technologies like cloud computing, automated solutions, and the Internet of Things have been incorporated

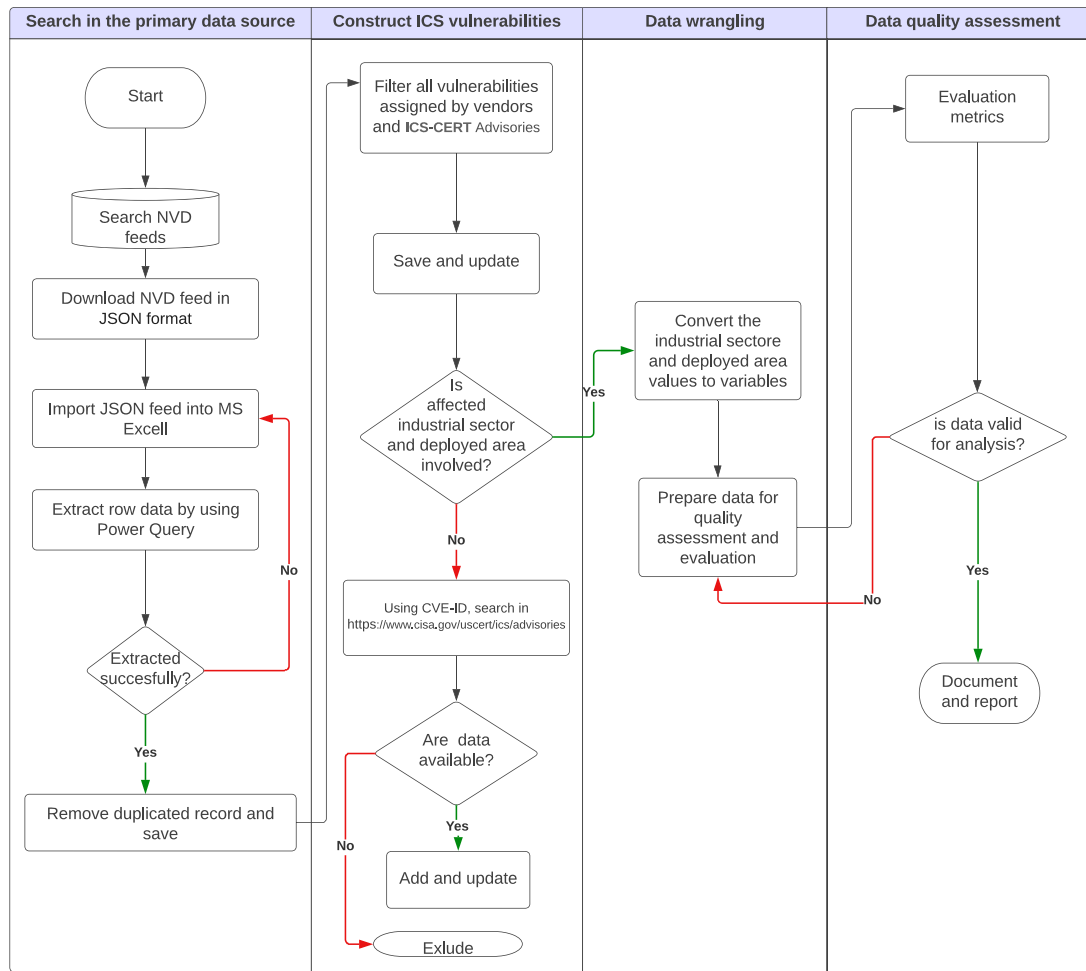


Fig. 5. ICS-LTU2022 dataset creation method.

into ICS. It is imperative to analyse newly discovered weaknesses in this interval. CVSSv2 was launched in 2007 and was widely adopted by vendors and enterprises as a common language for comparing software vulnerabilities. However, version two also had significant issues that needed to be addressed. Therefore, version 3.0 was released in 2015 to address the shortcomings of CVSS v2, providing a more accurate and comprehensive description of vulnerabilities (Howland, 2023). This makes it an accepted tool for evaluating weaknesses. The selected timeframe allows us to focus on the examined vulnerabilities and employ the more advanced CVSS v3-based system. Additionally, CVSS v3 maintains uniformity since it facilitates the analysis of vulnerabilities during the entire time frame. The consistency of CVSS versions is essential for performing comparative analysis and trend identification because it removes any differences from employing different versions of CVSS. Table 4 summarises the key differences between CVSS v2 and CVSS v3.

4.2. Data source and extraction

The dataset includes 66 variables obtained from multiple authoritative sources to provide a comprehensive depiction of ICS vulnerabilities. The National Vulnerability Database (NVD) feeds are the primary data source, with supplementary information obtained from CISA ICS-CERT advisory.

4.2.1. Manual data extraction

We used NVD feeds as our main data source since they provide comprehensive coverage and a detailed depiction of ICS vulnerabilities.

To enhance the relevance and specificity of the data, we filtered the NVD feeds by references to vendors and CISA ICS-CERT. This filtering ensured that the extracted data was pertinent to ICS systems. We manually collect the industry data because the CISA ICS CERT does not provide an API or feed to retrieve security advisories. We manually gathered supplementary data on industries and regions affected by the vulnerabilities. This information was obtained from CISA ICS-CERT using the vulnerability ID. Additionally, we manually collected data from CISA ICS-CERT to ensure that our dataset contains comprehensive information about the ICS components affected by the vulnerabilities.

4.2.2. Automated data extraction

We created a Python script to automatically extract the names of affected products and their version numbers from the descriptions in the NVD feeds. This automation reduced manual effort and increased the consistency of the extracted data (i.e., Compact GuardLogix 5370 controllers version 30.014).

4.3. Data wrangling

RStudio was used to manipulate our proposed dataset. While we were manually gathering information regarding industries and countries from the US-CERT website, we had a significant issue during data entry. For example, the country column had three values in a cell, including Asia, Europe, and the United States. The problem was that RStudio read these three values as one value (Asia Europe United States) because the factor categorised the data and stored them as

Table 4
The key differences between CVSS v2 and CVSS v3.

Dimension	CVSS v2	CVSS v3
Base Metrics	AV, AC, Au, C, I, A	AV, AC, PR, UI, S, C, I, A
Temporal Metrics	Exploitability, Remediation Level, Report Confidence	Exploitability, Remediation Level, Report Confidence (refined definitions)
Environmental Metrics	Collateral Damage Potential, Target Distribution, Security Requirements	Modified Base and Temporal metrics, Confidentiality Requirement, Integrity Requirement, Availability Requirement
Scope	Not explicitly defined	Explicitly included as a metric
Precision	broader categories	More precise assessments
Impact Metrics	Confidentiality, Integrity, Availability	Confidentiality, Integrity, Availability, Scope

levels. If we were to conduct data analysis on the ICS-related vulnerabilities in Europe, we would yield invalid results because they would match (Asia Europe United States). This issue could lead to inaccurate results during the data analysis process. To overcome this limitation, we converted the values to variables using a simple line of code, as follows:

```
SCADA2 <-
do.call("rbind", strsplit(as.character(df$COUNTRY)
, "\r\n",
fixed = TRUE))
```

This line of code split the values listed in a cell into columns based on the highest value of all variables in the dataset. It then checked the row data. If one value existed, it would be given a TRUE value in a new column.

4.4. Interpretation of variables

Table 5 describes the dataset's variables. We added the following features obtained from the ICS-CERT advisories and then articulated them with the NVD dataset to build a secondary vulnerability metadata for the industrial control system. Additionally, we have added two additional features (the name of the affected product and the version number). Hence, the dataset has 1881 entries and 66 variables as follows:

- Vendor information: This feature was collected manually from the correspondent resources
- Assigned Year: This feature was collected according to the year where the vulnerability was assigned to the affected product.
- The regions that deploy the affected product in their critical infrastructure were collected from the ICS US-CERT advisories.
- The critical infrastructure sector that deploys the affected product was collected from the ICS-CERT advisories.
- The affected ICS products were extracted from the vulnerability description in NVD feeds. Additionally, we developed a Python script to extract the name and version of the affected product automatically.
- Using R studio, consequences were extracted from the vulnerability description in NVD feeds.

5. Data analysis

Our dataset has 1881 entries and 64 variables. We conducted an analysis of vulnerabilities based on the top ten trends.

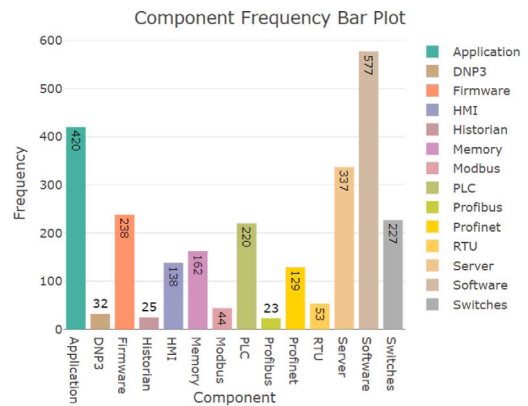


Fig. 6. Affected ICS products.

5.1. Affected ICS products

Fig. 6 illustrates the top 10 trends of vulnerabilities in ICS components from 2016 to the first half of 2023. It can be seen that the largest number of vulnerabilities affecting ICS components was identified in software (577), followed by web-based applications (420) and servers (337). Also, a wide range of vulnerabilities in ICS systems was identified in firmware (238) and switches (227). Overall, ICS network protocols (i.e. Modbus, Profibus, and DNP3) showed downward trends, while SCADA software showed upward trends over the period. Fig. 14 describes the most frequent vulnerabilities targeted in ICS main components.

5.2. Vulnerabilities identified by year

An estimated 404 vulnerabilities were identified in 2018. This number declined in the year 2019 but significantly increased over the years 2021 and 2023. These trends are illustrated in Fig. 7.

5.3. Analysis by most affected organisational sectors

Most vulnerabilities affected ICSs in critical manufacturing (1153), energy (986), emergency services, and water systems (705). By contrast, the fewest vulnerabilities were in food and agriculture (445), chemical sectors (426), and communications (374). These are illustrated in Fig. 8.

Table 5
The ICS-LTU2022 dataset variables.

Variable name	Data type	Description
Vulnerability ID	String	A unique identifier for vulnerabilities. CVE IDs are used by cybersecurity researchers and manufacturers as a standard method for identifying vulnerabilities and for cross-linking to other repositories that also use CVE IDs. The CVE ID syntax involves the CVE prefix + year + sequence number digits (e.g. CVE-2021-12345).
Assigned year	Numeric	The year an affected product was assigned to a vulnerability
Vendor	CHAR	The entity that sells a particular product (e.g. Schneider Electric, Emerson, Honeywell, Siemens, and ABB).
Vulnerability name	String	The type of vulnerability that was assigned to the affected product. CVE and the NVD use CWE to enumerate vulnerabilities.
Description	String	A brief description of the vulnerability.
Attack vector	String	The context in which an intruder exploits the vulnerabilities. This can be done physically, locally, remotely, or adjacently.
User_interaction	String	Indicates whether user interaction is required for the vulnerability to be exploited (e.g., Required, none).
Confidentiality	String	The consequences of reading data or memory.
Integrity	String	The consequences of modifying data or memory
Availability	String	The consequence of exploiting vulnerabilities in a targeted component by disrupting the system's operations.
CVSS	Float	Numerical representation, 0–10, of the severity of a vulnerability exploit.
Severity	String	The risk level or rank, covering low, medium, high, or critical.
REF	String	References to the information source about the vulnerability.
Asia	Boolean	Indicates whether the vulnerability affects systems in Asia.
Australia	Boolean	Indicates whether the vulnerability affects systems in Australia.
North_America	Boolean	Indicates whether the vulnerability affects systems in North America.
South_America	Boolean	Indicates whether the vulnerability affects systems in South America.
Europe	Boolean	Indicates whether the vulnerability affects systems in Europe.
East_Asia	Boolean	Indicates whether the vulnerability affects systems in East Asia.
Middle East	Boolean	Indicates whether the vulnerability affects systems in the Middle East.
United_States	Boolean	Indicates whether the vulnerability affects systems in the USA.
Canada	Boolean	Indicates whether the vulnerability affects systems in the Canada.
United_Kingdom	Boolean	Indicates whether the vulnerability affects systems in the UK.
Estonia	Boolean	Indicates whether the vulnerability affects systems in Estonia.
Latvia	Boolean	Indicates whether the vulnerability affects systems in Latvia.
Lithuania	Boolean	Indicates whether the vulnerability affects systems in Lithuania.
Finland	Boolean	Indicates whether the vulnerability affects systems in Finland.
Worldwide	Boolean	Indicates whether the vulnerability affects systems in worldwide.

Variable name	Data type	Description
Water	Boolean	Indicates whether the vulnerability affects the water systems.
Critical_Manufacturing	Boolean	Indicates whether the vulnerability affects the critical manufacturing.
Energy	Boolean	Indicates whether the vulnerability affects the energy systems.
Transportation_System	Boolean	Indicates whether the vulnerability affects the transportation sector.
Healthcare_PublicHealth	Boolean	Indicates whether the vulnerability affects the public health sector.
Nuclear_Reactors	Boolean	Indicates whether the vulnerability affects the public nuclear systems.
Defense_Industrial_base	Boolean	Indicates whether the vulnerability affects the defence industrial base sector.
Government_Facilities	Boolean	Indicates whether the vulnerability affects the government facilities.
Emergency_Services	Boolean	Indicates whether the vulnerability affects the public health sector.
Financial_Services	Boolean	Indicates whether the vulnerability affects the financial service sector.
Commercial_Facilities	Boolean	Indicates whether the vulnerability affects the commercial facility sector.
Information_Technology	Boolean	Indicates whether the vulnerability affects the IT sector.
Metals_Mining	Boolean	Indicates whether the vulnerability affects the mining and metal sector.
Food_Agriculture	Boolean	Indicates whether the vulnerability affects the food and agriculture sector.
Electrical_power_generation	Boolean	Indicates whether the vulnerability affects the power generation sector.
Chemical	Boolean	Indicates whether the vulnerability affects the chemical sector.
PLC	Boolean	Indicates whether the vulnerability affects the programmable logic controller.
RTU	Boolean	Indicates whether the vulnerability affects the remote terminal unit.
Historian	Boolean	Indicates whether the vulnerability affects the historian database.
HMI	Boolean	Indicates whether the vulnerability affects the human machine interface.
Firmware	Boolean	Indicates whether the vulnerability affects the firmware of control system.
Modbus	Boolean	Indicates whether the vulnerability affects the Modbus protocol.
Profinet	Boolean	Indicates whether the vulnerability affects the Profinet protocol.
Profibus	Boolean	Indicates whether the vulnerability affects the Profibus protocol.
DNP3	Boolean	Indicates whether the vulnerability affects the DNP3 protocol.
Memory	Boolean	Indicates whether the vulnerability affects the memory.
Server	Boolean	Indicates whether the vulnerability affects the application server of control systems
Switches	Boolean	Indicates whether the vulnerability affects the network switches.
Application	Boolean	Indicates whether the vulnerability affects the ICS web application.
Software	Boolean	Indicates whether the vulnerability affects the software components of ICS system.
Corruption	Boolean	Indicates whether the vulnerability impact lead to memory corruption.
Disclosure	Boolean	Indicates whether the vulnerability impact leads to information disclosure.
Arbitrary code execution	Boolean	Indicates whether the vulnerability impact leads to arbitrary code execution.
Buffer overflow	Boolean	Indicates whether the vulnerability impact leads to buffer overflow.
Privilege escalation	Boolean	Indicates whether the vulnerability impact leads to arbitrary administrative privileges.
Disruption	Boolean	Indicates whether the vulnerability impact leads to service disruption.
Affected_product_name	String	Refers to the name of affected product
Version_number	String	Refers to the version of affected product

5.4. Analysis by top 10 affected vendors and ICS products

Table 6 describes the top vendors' vulnerability disclosures. Siemens is a leading ICS vendor known for its SIMATIC products. Overall, it

has been exposed to several vulnerabilities and cyberthreats. The affected Siemens products included web applications, ICS software, PLC, RTU, and communication protocols. Additionally, ICS software and applications manufactured by Delta Electronic, Advantech, Rockwell

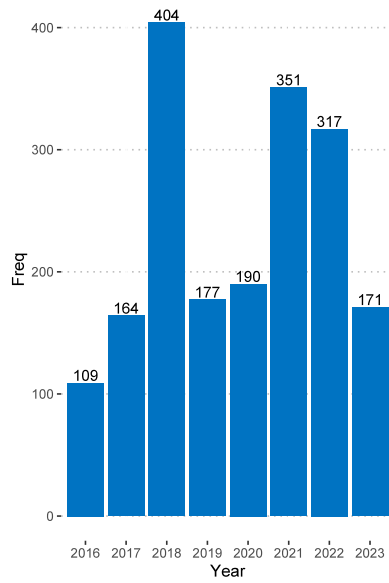


Fig. 7. Number of ICS vulnerabilities assigned by year.

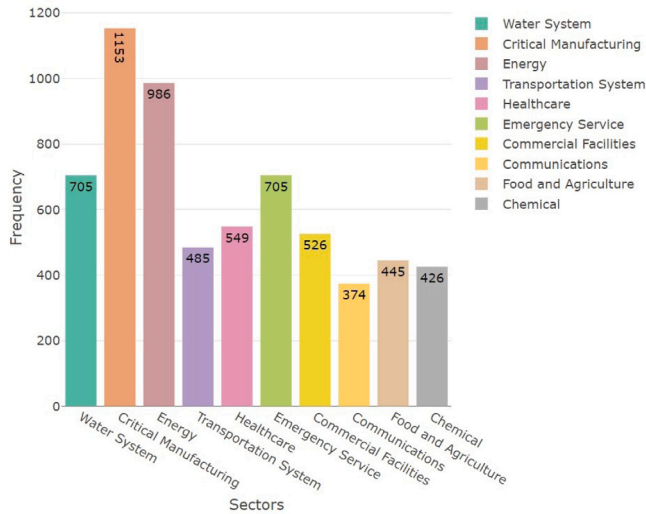


Fig. 8. Vulnerabilities analysis by industry.

Automation, Schneider Electric, and ABB were assigned to vulnerability disclosures. Furthermore, vulnerabilities in GE products could have remarkable implications for PLC and RTU. Other manufacturers, including LCDS, Omron, Fatek Automation, and Moxa had fewer affected software products compared with Siemens, Advantech, and Delta Electronic.

5.5. Correlation coefficients

Based on the results from Table 7, Europe had the highest number of vulnerabilities (N = 383) followed by the United States (N = 266) and East Asia (N = 152). While Asia (N = 60) also had a high number of vulnerabilities, Australia (N = 51) had the lowest number of vulnerabilities. The number of vulnerabilities worldwide was 1391.

Nations around the world have different critical infrastructures, including energy, manufacturing, transportation, and water supply systems. The technologies, equipment, and protocols used in these industries can introduce unique vulnerabilities that may be more prevalent in certain regions. In addition, these frameworks can impact the security

	SEVERITY1
Europe.	-0.082966390
United_states	-0.072832622
East_Asia	-0.075868225
Asia	-0.006889044
Australia	-0.042193003
Middle_east.	-0.042343097
North_America	-0.048114704
SEVERITY1	1.000000000

Fig. 9. Correlation coefficient between areas of the world and types of identified ICS vulnerabilities.

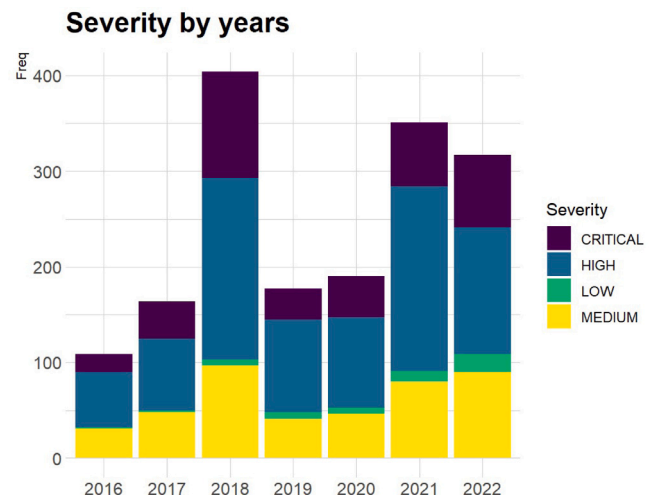


Fig. 10. Analysis by vulnerability severity by year.

requirements for ICS deployments and potentially affect the types of vulnerabilities observed. Fig. 9 shows the correlation coefficients between areas of the world and types of identified ICS vulnerabilities. Based on the results from Fig. 9, there was a weak positive correlation between the types of ICS vulnerabilities seen and Europe and East Asia, $r = 0.1$. This indicated that the types of ICS vulnerabilities seen were similarly related to Europe and East Asia.

There was a weak negative correlation between the types of ICS vulnerabilities seen and Asia, Australia, the United States, Europe, North America, and the Middle East, $r = -0.1$. This indicated a small decrease in the types of ICS vulnerabilities seen and the region: Asia, Australia, the United States, Europe, North America, and the Middle East.

We can conclude that vulnerabilities are not solely dependent on geographical factors. Vulnerabilities can emerge globally and affect ICSs irrespective of their locations.

6. Analysis by risk density

CVSS v.3.0 base scores of 7 or higher were assigned to more than half of the vulnerabilities identified in ICSs. This range of values corresponded to a high or critical level of risk. The number of vulnerabilities classified as high or critical significantly increased in 2018 compared with the previous year's data, as seen in Fig. 10.

Understanding the full range of ICS system is essential for developing a comprehensive security strategy to protect a system against cyberthreats. The severity of the vulnerabilities discovered across ICS

Table 6
Statistics of ICS top vendors' vulnerability disclosures (Years 2016–2023).

Vendor	Web application	Software	PLC	Communication protocols					RTU	Vulnerability count
				S7Comm	Modbus	Profibus	Profinet	DNP3		
Siemens	36	67	93	13	1	4	92	9	0	315
Advantech	33	22	0	0	0	0	0	0	1	56
Delta Electronics	69	71	2	0	0	0	0	0	0	142
Philips	16	34	0	0	0	0	0	0	0	50
Schneider Electric	6	19	5	0	2	0	0	0	2	34
Rockwell Automation	10	36	10	0	1	0	0	0	8	65
GE	10	0	7	0	5	4	0	0	3	29
Moxa	0	5	0	0	0	0	0	0	0	5
Fuji Electric	0	6	0	0	0	0	0	0	4	10
Omron	13	8	3	0	0	0	0	0	0	24
FATEK Automation	0	22	17	0	0	0	0	0	0	39
LCDS	3	2	0	0	0	0	0	0	0	5
WECON Technology	5	4	4	0	0	0	0	0	0	13
OSIsoft	3	0	0	0	0	0	0	0	0	3
ABB	10	5	2	0	0	0	0	0	0	17
AUVESY	0	17	0	0	0	0	0	0	0	17
Emerson	5	1	1	0	0	0	0	0	0	7
mySCADA	0	9	0	0	0	0	0	0	0	9
Honywell	0	0	1	0	0	0	0	0	1	2
TOTAL	219	328	145	13	9	8	92	9	19	842

Table 7
Vulnerability frequency by region.

Region	Vulnerabilities
worldwide	1391
Europe	383
United states	266
East Asia	152
Asia	60
Australia	51
Middle East	31
North America	60

system, as identified in Section 5.1 and Section 6, including web applications, hardware, software and network/host deployments, is presented below in a breakdown.

6.1. ICS web application vulnerabilities

The ICS web application is an application that provides a web-based interface for monitoring and controlling ICS systems. It allows users to access and manage ICS functionalities remotely through a web browser. However, ICS web-based applications are vulnerable to potential cyberthreats due to increased remote access and the presence of the cloud environment. Several factors can contribute to a rise in cyberthreats, such as improper input validation, insecure communication channels, improper access controls, or misconfiguration security. The severity of vulnerabilities ranges from low impact to critical, depending on the attack complexity and payload delivery method. Critical and higher-severity vulnerabilities can lead to more significant consequences, including unauthorised access, information disclosure, and the potential disruption of critical infrastructure.

The pie chart provides the top 10 high-severity vulnerabilities in ICS web applications 11. Overall, buffer overflow remained a prominent concern in the realm of ICS web applications, emerging as a primary issue in terms of security vulnerabilities. In the context of ICS web applications, buffer overflow vulnerabilities occur when the input data received from a user is not properly validated. Adversaries can exploit this vulnerability by intentionally providing excessive input that exceeds the allocated buffer size, causing the excess data to overflow into adjacent memory locations. When a buffer overflow occurs, it can have severe consequences. Attackers may be able to manipulate the overwritten memory contents, leading to unauthorised access, control manipulation, or malicious code execution. This can compromise the availability, integrity, and confidentiality of the ICS web application and potentially impact the underlying SCADA system. For example, CVE-2019-3975 indicates a critical stack overflow vulnerability within

WebAccess/SCADA, manufactured by Advantech version 8.4.1. The vulnerability can be exploited remotely by sending a crafted IOCTL 70603 RPC message, causing remote code execution. The next major segments of the top 10 high-risk vulnerabilities in ICS web applications included improper input validation, out-of-bounds read, and out-of-bounds write. When added together, those categories made up two-thirds of the top 10 high-risk vulnerabilities in ICS web applications. Due to improper input validation, CVE-2019-10987 was assigned to multiple out-of-bounds write and out-of-bounds read vulnerabilities identified in Advantech WebAccess/SCADA 8.3.5. By contrast, the categories with the lowest percentages of high-risk vulnerabilities included uncontrolled resource consumption (9%), heap-based overflow (8%), improper authentication and path traversal (6%), and SQL injection (5%) of high-risk ICS web application security. Such vulnerabilities lead to potential cyberattacks against ICS web applications, including SQL injections and XSS, which prioritise operational impacts rather than confidentiality impacts (Larkin et al., 2014). The consequences of ICS attacks can be immediate and severe, affecting public safety, industrial operations, and critical infrastructure resilience.

6.2. ICS software vulnerability

ICS serves as the underpinning technology for several critical infrastructures and manufacturing. As described in Section 5.1, SCADA software has the largest number of ICS vulnerabilities. To enhance data readability, we grouped high and critical SCADA software vulnerabilities into categories according to the vulnerability taxonomy in Alanazi et al. (2023), as presented in Fig. 12.

Fig. 13 represents the common software vulnerabilities related to industrial control systems. Weaknesses related to improper input validation, handling, or representation, such as buffer overflow, integer overflow, and out-of-bounds read and write made up more than two-fifths (42%) of the software vulnerabilities related to ICS systems. The second largest proportion of common high-risk vulnerabilities was related to improper input validation, representing nearly a fifth (20%) of the most frequent ICS software vulnerabilities. Similarly, one-fifth of the weaknesses were related to improper access control, including authentication and authorisation. For example, the Wonderware platform provides real-time data visualisation, alarming, and historical data analysis for industrial automation. This platform was assigned to unauthorised access to credentials vulnerability CVE-2019-6525, with a high severity base score for confidentiality, integrity, and availability (ACDA, 2023). By contrast, lack of encryption represented less than one-fifth (15%) of the ICS software vulnerabilities.

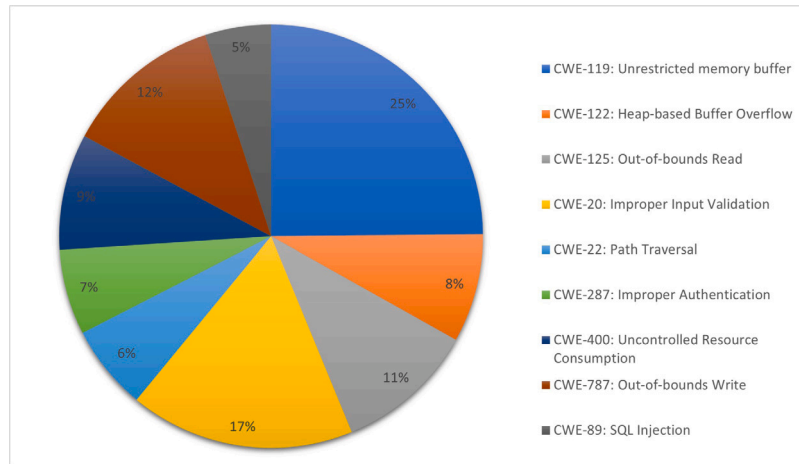


Fig. 11. Analysis by top 10 high-risk vulnerabilities in ICS web applications.

Vulnerability Category	Count
Lack of Input Validation	128
CWE-119: Unrestricted memory buffer	17
CWE-121: Stack-based Buffer Overflow	24
CWE-122: Heap-based Buffer Overflow	9
CWE-125: Out-of-bounds Read	21
CWE-787: Out-of-bounds Write	27
CWE-190: Integer Overflow or Wraparound	9
CWE-20: Improper Input Validation	21
Poor Access Control	61
CWE-284: Improper Access Control	9
CWE-287: Improper Authentication	12
CWE-306: Missing Authentication for Critical Function	7
CWE-406: Insufficient Control of Network Message Volume	4
CWE-434: Unrestricted Upload of File with Dangerous Type	5
CWE-522: Insufficiently Protected Credentials	4
CWE-732: Incorrect Permission Assignment for Critical Resource	5
CWE-798: Use of Hard-coded Credentials	11
CWE-824: Access of Uninitialized Pointer	4
Lack of Encryption	9
CWE-311: Missing Encryption of Sensitive Data	5
CWE-312: Cleartext Storage of Sensitive Information	4
Lack of Input Sanitization	63
CWE-77: Command Injection	4
CWE-78: OS Command Injection	7
CWE-79: Cross-site Scripting	8
CWE-89: SQL Injection	44
Others	47
CWE-22: Path Traversal	10
CWE-400: Uncontrolled Resource Consumption	8
CWE-427: Uncontrolled Search Path Element	6
CWE-416: Use After Free	6
CWE-426: Untrusted Search Path	4
CWE-476: NULL Pointer Dereference	4
CWE-502: Deserialization of Untrusted Data	9

Fig. 12. Vulnerability category by most frequent high-risk vulnerabilities in ICS software.

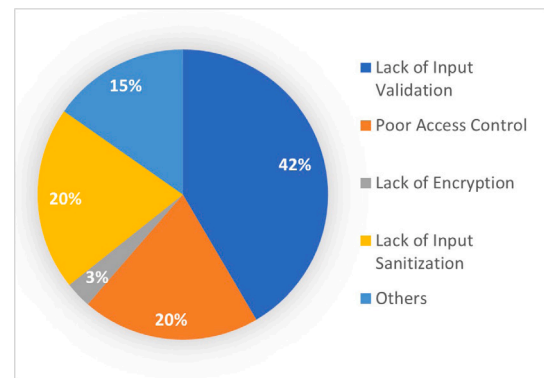


Fig. 13. Analysis by most frequent high-risk vulnerabilities in ICS software.

7.1. Lack of input validation

Insufficient input validation in ICS systems is a notable weakness that can have significant security implications. It can occur in various ways within ICS systems. Here are some common scenarios where this weakness may arise:

- **Weak validation logic:** An attacker can bypass input validation checks when the validation logic is not implemented correctly. It occurs when the validation rules are not strict enough or fail to cover all potential input scenarios (Upadhyay and Sampalli, 2020).
- **Trusting client-side validation:** Relying solely on client-side validation, such as JavaScript-based validation, is a common mistake. Client-side validation can be easily bypassed or manipulated by attackers, as the validation logic is executed on the user's device rather than on the server's side (ACDA, 2023; Alanazi et al., 2023; Osman et al., 2022).
- **Inadequate length and size checks:** Failure to validate the length and size of input can result in buffer overflow vulnerabilities. If the input fields are not properly constrained, attackers can submit excessively long data, potentially leading to memory corruption or system crashes (Banga et al., 2019).
- **Weak error handling:** Improper error handling can provide valuable information to attackers. Detailed error messages or stack traces may reveal system vulnerabilities or assist attackers in formulating targeted attacks. A lack of input validation can contribute to error conditions that expose sensitive information (Franco et al., 2019).

7. Comprehensive discussion of common ICS vulnerabilities

In this discussion, we delve into the top 10 architectural weaknesses of ICS components and provide illustrative examples of these vulnerabilities.

Various versions of SIMATIC S7-400, S7-400 PN/DP, S7-400H, and S7-410 systems lack input validation. A malicious user can conduct a DoS attack by sending crafted packets to port 102/TCP via PROFIBUS or multi-point interfaces. An adversary does not require specific privileges to exploit this security flaw if access control is not configured. A successful exploit leads to a DoS condition, compromising the system's core functionality. According to the United States Department of Homeland Security, there are no known instances of public exploitation of this security vulnerability (CISA, 2023t).

7.2. Stack-based buffer overflow

A stack overflow vulnerability in a ICS system occurs when a program within the system attempts to write data beyond the allocated stack memory, leading to the corruption of adjacent memory addresses (Alanazi et al., 2023). Malicious actors can leverage this security weakness to gain unauthorised control over the ICS system. Severe consequences are associated with stack overflow vulnerabilities in ICS systems. An adversary can exploit the vulnerability by providing malicious input that exceeds the allocated buffer size, resulting in buffer overflow. Consequently, the adversary can overwrite critical data on the stack, such as return addresses and function pointers. A successful exploit leads to malicious payload injection, remote code execution, and privilege elevation. The stack overflow vulnerability was assigned to various controller models, specifically CompactLogix 22023 L22023, L2, L3 controllers, Compact GuardLogix 5370 controllers, and Armor Compact GuardLogix 5370 controllers. This vulnerability affected the versions ranging from 20 to 30.014, including earlier releases. By sending specifically crafted SMTP packets, an attacker could trigger a DoS scenario to force the controller into a major non-recoverable faulted state (CISA, 2023r). In addition, a stack overflow vulnerability was identified in LAquis SCADA V 4.1.0.3870. In the context of processing project files, the application failed to sufficiently sanitise user input prior to executing write operations on a stack object. This weakness could lead to arbitrary code execution within the current process (CISA, 2023t). Other stack overflow vulnerabilities were assigned to WebAccess version 8.3.1 and earlier, PLC Editor, ladder logic software, version 1.3.520190129, and Modbus Slave versions 7.4.2 and prior (CISA, 2023o,x,c).

7.3. Heap-based buffer overflow

A heap overflow scenario occurs when a program attempts to write data beyond the bounds of an allocated heap buffer, resulting in the corruption of adjacent memory areas (Banga et al., 2019). This vulnerability typically arises due to improper memory management or incorrect validation of user-supplied input. If successfully exploited, it leads to severe consequences, including system crashes, information exposure, operation disruption, and malicious command injection, in the underlying infrastructure. A heap overflow vulnerability was identified in Advantech WebOP. Heap overflows could be triggered by specially crafted project files. In such a case, an adversary could potentially execute arbitrary code and perform further malicious activities. CISA (2023f). Additionally, PLC management software Horner Automation Cscape Csfont: Versions 9.90 SP5 (v9.90.196) and prior was assigned to a heap-based overflow vulnerability by an uninitialised pointer (CISA, 2023l). This vulnerability could create the potential for arbitrary code execution.

7.4. Out-of-bounds read

An out-of-bounds read vulnerability in a ICS system refers to a security flaw in which a program accesses or reads data from a memory location outside the boundaries of a valid memory region. It can occur due to improper bounds checks or the incorrect handling of user input. By providing crafted inputs that exceed the expected bounds of an

array or buffer, an attacker can trick a system into reading unintended data from adjacent memory locations (Alsmadi et al., 2022; Alanazi et al., 2023). For example, WebAccess HMI 2.1.9.31, WinProLadder PLC: Versions 3.30 and prior, WebAccess Node 8.4.4, and LCDS Laquis SCADA prior to version 4.1.0.4150 were assigned to an out-of-bounds read vulnerability (CISA, 2023c,b,n,i). An out-of-bounds read vulnerability can lead to unauthorised access to critical data, disclosure of sensitive information, or disruption of system operations if successfully exploited. Additionally, attackers may leverage the information obtained from out-of-bounds reads to launch further attacks or exploit other vulnerabilities within the system.

7.5. Out-of-bounds write

An out-of-bounds write vulnerability occurs when a program writes data to a memory location beyond the bounds of a valid memory region. This vulnerability arises due to improper bounds checking or improper validation of user-supplied input. Providing malicious input that exceeds the expected bounds of an array or buffer can allow an attacker to overwrite unintended memory locations, potentially compromising the integrity of the system (Upadhyay and Sampalli, 2020). The Modicon M218 Logic Controller (V5.0.0.7 and earlier) was assigned to an out-of-bounds write vulnerability (CISA, 2023w). This vulnerability could be exploited by sending crafted IPv4 packets to the controller, causing a DoS condition. Additionally, WebAccess/SCADA version 8.3 was assigned to an out-of-bounds write vulnerability because of improper handling of user inputs (CISA, 2023c). When exploited successfully, critical data can be modified, system operations can be disrupted, and arbitrary commands can be executed on the underlying infrastructure.

7.6. Integer overflow or wraparound

An integer overflow vulnerability occurs when an integer variable stores a value that exceeds the maximum range of allocated memory. This vulnerability can occur when calculations are performed using integers without proper validation or error handling. Wraparound vulnerabilities in ICS systems can have unintended consequences and pose risks to system integrity and reliability. They can result in inaccurate calculations, incorrect data processing, or unexpected behaviour of control processes. This can potentially compromise the functionality and stability of the ICS system (Jung et al., 2021). Earlier versions of Advantech WebAccess had been affected by an integer overflow vulnerability in the kernel service. A specially crafted RPC request could trigger a stack overflow, which allowed remote attackers to execute arbitrary code or launch DoS attacks (CISA, 2023d). Additionally, LAquis SCADA 4.1.0.3870 was vulnerable to multiple vulnerabilities involving integer overflow that could result in buffer overflow. CISA (2023n). A remote code execution could be conducted by exploiting these vulnerabilities.

7.7. Cross-site scripting

Cross-site scripting (XSS) in ICS web applications refers to a security vulnerability in which an attacker injects malicious scripts into web pages viewed by users of the ICS system. Consequently, it provides attackers with the opportunity to access sensitive information, grant control over system functionality, or carry out actions on the user's behalf without authorisation (Alanazi et al., 2023; Upadhyay and Sampalli, 2020). In the case of ICS systems, XSS vulnerabilities in web applications can have severe consequences. They can enable attackers to gain unauthorised access, tamper with control processes, manipulate data, or disrupt the normal operation of the system. For example, an XSS vulnerability was found in Siemens SICAM RTUs SM-2556 COM Modules, specifically in the firmware variants ENOS00, ERAC00, ETA2, ETLS00, MODi00, and DNPi00. The issue resided in the integrated

web server (port 80/tcp) of affected devices, potentially enabling XSS attacks when unsuspecting users were prompted to click on a malicious link (CISA, 2023u). Another XSS security vulnerability was identified in the ABB GATE-E1 and GATE-E2 versions of Pluto Safety PLC Gateway Ethernet devices. This vulnerability could allow a remote attacker to inject an HTML/Javascript payload into a targeted device and control the administrative web interface (CISA, 2023a). Additionally, WebAccess/SCADA version 9.0 was assigned to XSS vulnerability. Upon a successful exploit, this attack vector could lead to the unauthorised acquisition of the user's cookies, session tokens, or redirection to a malicious webpage (CISA, 2023e).

7.8. SQL injection

An SQL injection vulnerability in ICS systems refers to a security issue wherein an attacker can manipulate the input parameters of an SQL query to execute unintended SQL commands or obtain unauthorised access to the underlying database (Alanazi et al., 2023). It occurs when user-supplied input lacks proper validation or sanitisation. Attackers can exploit this weakness by inserting malicious SQL code into input fields, causing the database server to execute it. Advantech WebAccess Node versions 8.4.4 and prior were assigned to improper input neutralisation (CISA, 2023c). A successful exploit could allow an adversary to inject SQL commands. eDNA Enterprise Data Historian version 3.0.1.2/7.5.4989.33053 contained a security vulnerability in the CHAd.asmx web service functionality (CISA, 2023h).

7.9. Code and command injection

Code injection is a security weakness that allows an adversary to inject and execute malicious code. It can lead to severe consequences, such as data corruption, operation disruption, and information exposure. Code injection attacks occur when user input lacks appropriate validation or sanitisation before being interpreted or executed by the ICS system. The adversary exploits this weakness by injecting malicious code into input fields or parameters, tricking the system into executing the arbitrary code (Lee and Hong, 2021). ControlLogix 5580 controllers, GuardLogix 5580 controllers, CompactLogix 5380 controllers, CompactLogix 5480 controllers, and Compact GuardLogix 5380 controllers were assigned to code injection (CISA, 2023s). If an attacker were to gain administrator access on a workstation running Studio 5000 Logix Designer, they would have the capability to inject a controller code that goes unnoticed by the user. Another product affected by code injection was SIMATIC CP 1242-7 V2 (6GK7242-7KX31-0XE0), all versions prior to V3.3.46 (CISA, 2023v). A remote attacker could inject and execute a malicious arbitrary code with administrative privileges.

7.10. Improper access control

Improper access control is a security weakness in which the ICS fails to restrict user access and privileges. Misconfigured access control leads to bypassing authentication mechanisms, unauthorised control over system components, or sensitive data exposure. This can result in unauthorised system modifications, disruptions to operational processes, data breaches, or even physical harm (Johnson, 2010; Alanazi et al., 2023). In versions 8.3.2 and earlier of WebAccess, a critical security vulnerability was identified. During the installation process, the application installer would deactivate user access control but neglect to re-enable it once the installation was complete. Consequently, this flaw could provide an avenue for attackers to exploit the system by executing arbitrary code with elevated privileges (CISA, 2023n). Additionally, all versions prior to 8.20.0 of myPRO mySCADA were assigned to improper access control vulnerability (CISA, 2023p). All versions prior to 9.90 SP4 of Cscape, a control system application programming software, were affected by improper access control (CISA, 2023k). The affected product failed to prevent unauthorised access to

sensitive system information. It was configured with a default installation setting that enabled configuration for all users, granting read and write access. Consequently, unprivileged users could modify the configuration files, leading to local privilege escalation.

7.11. Improper authentication

Improper authentication is a security weakness in which authentication mechanisms are not implemented correctly. An attacker can exploit this vulnerability by bypassing authentication controls, such as weak passwords and lack of multi-factor authentication. Thus, a malicious user can impersonate authorised users and gain access to critical ICS components. The web server in Phoenix Contact ILC PLCs had a critical security vulnerability that allowed access to read and write PLC variables without requiring any authentication (CISA, 2023q). Consequently, it allowed unauthorised users to access and modify PLC variables without any form of authentication or authorisation. The CLICK PLC CPU modules, specifically the C0-1x CPUs with firmware versions prior to v3.00, were identified with a significant security vulnerability. Whenever an authorised user unlocked the PLC, the unlocked state did not have a timeout feature, meaning it remained unlocked indefinitely. Consequently, if the programming software were to be interrupted, the PLC remained unlocked, permitting subsequent programming connections without any form of authentication or authorisation (CISA, 2023g).

7.12. Lack of encryption

Lack of encryption occurs when the ICS fails to protect the confidentiality and integrity of data transmitted between ICS components. When encryption is not employed, communication channels within the ICS system become vulnerable to eavesdropping, data tampering, and unauthorised data disclosure. Attackers can intercept network traffic and gain access to critical information, such as control commands, sensor readings, and other sensitive data. ControlEdge PLC (R130.2, R140, R150, and R151) and RTU (R101, R110, R140, R150, and R151) were assigned to the lack of encryption vulnerability. A malicious user could intercept the session token and gain unauthorised access to the affected devices (CISA, 2023j). Exposing the session token on the network could present a security risk whereby potential attackers could intercept the token. Consequently, it allowed the adversary to pretend to be a legitimate user and access sensitive information or control functions without permission. It could lead to unauthorised access to the PLC or RTU, compromising the availability of critical services. PR100088 Modbus gateway was also assigned to the lack of encryption vulnerability (CISA, 2023m). An adversary could obtain plain-text credentials stored within an XML file via FTP. A successful exploit could lead to unauthorised access to sensitive credentials, causing further exploitation of the affected gateway.

7.13. Main findings

Our analysis of Industrial Control Systems (ICS) networks highlights software as the most vulnerable product, followed by applications and servers. ICS environments rely on legacy software that may be outdated and no longer supported by vendors. There are vulnerabilities in legacy systems that are not patched, which attracts malicious users to exploit them and commit malicious acts. Thus, applying patches can be challenging due to the operational nature of the ICS system. As a result, software vulnerabilities might not be updated for extended periods, increasing the risk of exploitation. Common vulnerabilities in software include improper inputs validation, coding errors, buffer overflows, insecure configurations, and lack of patch management can compromise the integrity, confidentiality, and availability of industrial processes. Applications and servers within ICS networks are also vulnerable to

various security threats, including code injection, unauthorised access, SQL injection, XSS, and denial-of-service attacks.

The primary objective of analysing ICS vulnerabilities according to the assigned year is to identify trends and factors that led to the threat evolution. Several factors led to increased vulnerability volume in the context of the ICS system. Firstly, the adaption of new technologies. Until 2018, there was a sharp increase in the number of vulnerabilities due to the adoption of the Internet of Things (IoT) and Industry 4.0 (the fourth industrial revolution) (Upadhyay and Sampalli, 2020). From 2019 to 2022, the number of vulnerabilities fluctuated until 2021, when we noticed a massive spike in total vulnerabilities. Since then, vulnerabilities have steadily decreased throughout the remainder of 2022. Remote access could lead to an increase in vulnerabilities between 2020 and 2022. Access to large datasets on remote networks and mobile platforms increases the likelihood of a breach.

Our analysis also shows that the industrial sectors most affected by vulnerabilities are critical manufacturing, followed by energy and water supply systems. They are responsible for storing and processing sensitive operational data, manufacturing processes, and critical infrastructure. Adversaries target this information for financial gain and espionage (Wueest, 2014). They also target the energy sector to steal intellectual property such as photovoltaic research and wind turbines (Wueest, 2014). Furthermore, water distribution systems are attractive targets for terrorists and cyber warfare due to their safety-critical nature (Taormina et al., 2017).

Vendor-related vulnerabilities can cause significant security risks to ICS systems, and their risk density impacts the overall security posture of these systems. The potential impact of exploiting vendor-related vulnerabilities in ICS systems can vary widely, depending on factors such as the criticality of the affected processes, the accessibility of the vulnerable components, and the skill level of the attackers. High-impact vulnerabilities that could result in operational disruptions, safety incidents, or financial losses contribute to the overall risk density of ICS systems. For example, Stuxnet exploited multiple vulnerabilities to infiltrate and sabotage nuclear enrichment facilities, notably the Natanz facility in Iran. Stuxnet exploited several zero-day vulnerabilities in Siemens' WinCC and Step 7 software. It could infect other ICS components and propagate across networks without detection. These vulnerabilities included weaknesses in the MS10-046 Windows operating systems handling shortcut files (CVE-2010-2568) and WinCC parsed project files (CVE-2010-2772). A successful exploit of the Siemens software, Stuxnet was able to gain unauthorised access to the PLCs, manipulate their operation, and cause physical damage to the centrifuges. This unauthorised access compromised the integrity and security of the ICS, causing disruptions in critical industrial processes. It demonstrated the real-world impact of vulnerabilities in vendor-supplied software on the security and functionality of ICS environments.

High-criticality vulnerabilities pose the highest risk to the ICS environment, causing severe operational disruptions. Illustration of critical vulnerabilities that cause operation disruption are as follows:

- A timeout during a TLS handshake can result in a denial of service, disrupting communication between critical systems.
- CRLF injection vulnerability in Ecava IntegraXor can lead to unauthorised command execution.
- Parsing malformed project files in Omron CX-One can result in execution of arbitrary code.
- VT-Designer is vulnerable to deserialization of untrusted data, allowing remote code execution.

The analysis in Table 8 indicates that the ICS products have a higher frequency of vulnerabilities with severe degrees of impact. It suggests that the ICS components included in this dataset are more vulnerable to significant vulnerabilities. The increased number of vulnerabilities with higher severity levels in the dataset suggests that the ICS products provided by vendors, such as Siemens, Advantech, and Delta Electronics, are more vulnerable to severe vulnerabilities. Furthermore,

it indicates that vulnerabilities related to input validation (CWE-20), cross-site scripting (CWE-79), and memory buffer concerns (CWE-119) are evolving significantly.

7.14. Considerations for professionals

Developers must adhere to the following recommendations to enhance the security posture of ICS systems. They provide practical guidelines and best practices for mitigating potential cyber risks and protecting critical infrastructure.

7.14.1. Secure coding practice

Secure coding practices are fundamental principles and techniques employed by developers to minimise vulnerabilities and enhance the overall security of software applications (Graff and Van Wyk, 2003). It paves the way for developers to reduce the risk of security breaches, unauthorised access, and cyberattacks by developing secure software.

It involves several aspects, such as proper input validation, proper handling of sensitive data, cryptographic practices, output encoding, and secure communication. The incorporation of secure coding practices into software development processes can significantly contribute to the resilience and robustness of applications.

Homeland Security in 2015 highlighted that the unsafe function calls in a proprietary application, particularly in OPC dynamic-link libraries (DLLs), can make the ICS system vulnerable (CISA, 2018; Makrakis et al., 2021). Therefore, vendors or asset owners should conduct special training programs for ICS developers to educate them about secure coding practices.

While data confidentiality is highly important in information technology and general computer systems, it is less critical in ICS systems. In other words, the availability of ICS service in industrial domain is the most important. For software applications in the context of industrial control systems, this prioritisation means applying secure coding guidelines should not halt the operations (Response time) for application time critical components such as programmable logic controllers (PLC). Employing secure coding guidelines in such components is a challenging task requiring insightful knowledge of both security and control. The Department of Homeland Security (DHS) recommends that ICS vendors and developers integrate IT secure coding guidelines (Seacord (2013); Kissel et al. (2008)) into industrial applications, but the specific implications for the ICS domain are not detailed (Kuipers and Fabro, 2006). Utilising vendor libraries introduces several challenges, ranging from security vulnerabilities and patch delays to hidden dependencies and lack of customisation. For critical environments such as ICS systems, the risks are amplified due to the potential impact of a security breach. Therefore, close collaboration with vendors is essential to ensure that the libraries used are secure, well-supported, and aligned with the organisation's specific requirements. Scott and CICIP (2023) suggested to follow the three steps in the employment of secure coding practices. The first step includes establishing security coding environment which is function specific. The software functional feature security requirements are essential criteria in selecting a code base. After identifying the code base, it has to be examined for known flaws and vulnerabilities. Architectural vulnerabilities and weaknesses discovered by code developers are stored in international security repository like the Open Web Application Security Project (OWASP), Common Weakness Enumeration (CWE), the US National Institute of Standards and Technology (NIST), and National Vulnerability Database (NVD). Developers can reduce software and architectural vulnerabilities by using these repositories as a Ref. Smith (2019). Alternatively, if a software functional feature requires the use of a weak element, they can implement industry-verified mitigations (workarounds or preventive measures) that mitigate the vulnerability Scott and CICIP (2023). The final stage involves selecting software analysis tools to validate the code. These tools must be capable of configuring for the specific code base and establishing coding guidelines.

Table 8
The distribution of vulnerability by Severity.

Severity	CVSS score	Number of vulnerabilities	Percentage
Low	0.1–3.9	53	2.82
Medium	4.0–6.9	468	24.89
High	7.0–8.9	924	49.15
Critical	9.0–10.0	435	23.14

All code is scanned by a preconfigured verification tool to check if it follows the main rule sets. The verification tool cannot analyse certain architectural features or specific security measures. Therefore, all ICS software must be manually reviewed by secure coding experts.

7.14.2. Secure authentication and authorisation

Secure authentication and authorisation mechanisms are crucial in ensuring system resources' integrity and confidentiality in any software application. It involves employing robust authentication methods, such as multifactor or token-based authentication, to validate the identity of users accessing the system. Additionally, a fine-grained access control mechanism based on user roles and privileges guarantees that only authorised users can perform specific functions or access sensitive information (Tellabi et al., 2018; Park et al., 2021). Software developers can minimise information exposure and system compromise by prioritising secure authentication and authorisation mechanisms.

7.14.3. Least privilege principle

The principle of least privilege (PoLP) is a fundamental concept in security that states that individuals or processes should only have the minimum level of access privileges necessary to perform their required task. The PoLP is crucial for minimising potential security risks and protecting critical infrastructure. It can ensure that users, processes, and devices have the necessary permissions and privileges to perform their assigned functions (Venugopal et al., 2019). This approach helps to prevent the spread of malware and reduce the attack surface for potential exploits. Understanding the roles and permissions of each entity within the system helps developers apply the PoLP effectively. Hence, each entity will be granted minimal permissions to perform its assigned task. Regular monitoring, auditing, and review processes are also essential to ensure compliance with the PoLP (Abou el Kalam, 2021). Therefore, software developers can enhance the security posture of ICS systems and minimise the potential impact of security breaches or unauthorised activities.

7.14.4. Secure software development life cycle

The secure software development life cycle (SSDLC) is a structured, cost-effective, and time-saving approach used for high-quality software development. Thus, software developers can design software applications with enhanced security features and minimise potential cyberthreats.

An SSDLC comprises several phases: requirements gathering, design, implementation, testing, deployment, and maintenance (Eckhart et al., 2019). In the first phase, the development team estimates costs and collects requirements to create new software. The design phase includes security architecture and controls (Raj et al., 2014). Additionally, threat modelling can be employed in the design phase to quantify vulnerability criticality and prioritise appropriate defensive mechanisms (Khalil et al., 2023). Software developers follow secure coding practices during implementation, such as output encoding, input validation, and proper handling of user inputs. Furthermore, extensive testing, including code evaluation, vulnerability assessments, and penetration testing, is performed during the testing phase. It helps identify any security weaknesses and mitigate them before deploying the application. The deployment phase involves testing a different software version in a production environment. A rollback strategy is designed before the roll-out from a test environment to the production environment. Rolling back aims to fix bugs, restore functionality, avoid

conflicts, or comply with regulations. Rolling back can be conducted manually or automatically, depending on the tools and approaches used in the software development life cycle (Rossberg, 2014).

Finally, maintenance occurs when the running system is subject to a new business requirement. In this phase, developers fix bugs and resolve customer issues. In addition, the team monitors overall system performance, security, and user experience to identify new ways to improve the existing software.

7.14.5. Secure configuration management

Secure configuration management establishes an organisation's network, software, and hardware configurations. It includes the implementation of configuration settings that align with cybersecurity best practices. It involves defining a set of security settings, such as password policies, encryption requirements, access controls, and network configurations compliant with industry standards and organisational policies. Additionally, maintaining up-to-date and accurate configurations for the hardware, software, and network settings is vital. This approach facilitates the rapid resolution of configuration issues. Furthermore, periodic audits and continuous configuration monitoring are essential to detect and manage unauthorised variations of system configurations. Auditing and monitoring can involve automated tools to track variations and generate alerts for non-compliant configurations. Finally, combining configuration management with vulnerability management helps identify and remediate configuration-related vulnerabilities (Kilman and Stamp, 2005).

7.14.6. Secure third-party components

Secure third-party components refer to software or hardware components that are developed by external vendors and integrated into an organisation's ICS systems. These components include dependencies that provide additional functionality to the system, such as libraries and frameworks. They ensure that the integrated components are up to date, secure, and properly managed (Larkin et al., 2014).

7.14.7. Secure communication

Secure communication is vital to ensure the confidentiality, integrity, and authenticity of data transmitted within ICS systems. Although secure versions of legacy protocols, including S7 Secure and OPC UA, are often promoted as solutions for weaknesses in previous ICS protocols, they can still introduce vulnerabilities (Pliatsios et al., 2020). For example, improper implementation of the extensions or requirements for backward compatibility can leave ICS systems vulnerable to flaws in legacy protocols. To establish secure communication channels, the following practices should be implemented:

Encryption: Weak encryption methods have been historically introduced in Siemens S7 protocols, and in many cases, these protocols were designed under the assumption of air-gapped networks (Ayub et al., 2021). The lack of encryption led to several cyberattacks against ICS systems, such as interception and traffic manipulation. Several legacy systems still operate with outdated communication protocols, including the S7 protocol with weak encryption techniques. Consequently, it allows an adversary to bypass the authorisation and retrieve sensitive ICS data. S7 version one does not have any form of integrity protection. In contrast, the second version of the S7 protocol introduced security features against replay attacks (e.g., Hashed-based Message Authentication Code-Secure Hash Algorithm-256 (HMAC-SHA-256)). The third

Vulnerability name	Description	ICS targeted component	Count of CVE entries
Improper authentication	Improper authentication occurs when SCADA system or application fails to properly authenticate the identity of users.	Communication protocols	109
		Administrative interface	
		Remote Access and Connectivity Modules:	
Lack of input validation	When SCADA systems lack proper input validation, it can lead to various security risks. Without input validation, the SCADA system might accept malicious inputs, causing buffer overflows, injection attacks, and arbitrary code execution.	PLC application	103
		RTU	
		SCADA software	
		Web server	
		Network protocols	
		CPU devices	
		Firmware	
Cross-site Scripting	Cross-site scripting (XSS) occurs in SCADA web applications due to improper input sanitization. A successful exploit allows attackers to inject malicious scripts into web pages viewed by other users. Consequently, an attacker can bypass the authentication mechanism and read the application data.	Compact Logic PLC	98
		RTU	
		SCADA\HMI	
		Reporting and data visualization modules	
		User interface	
Stack-based buffer overflow	A stack-based overflow attack occurs due to the lack of input validation, where an attacker can craft input data that exceeds the boundaries of a stack buffer and overwrite adjacent memory locations. A successful exploit can impact the SCADA system's availability, confidentiality, and integrity.	HMI, PLC editor	80
		DLL files	
		SCADA host master station	
		HMI programming software	
		Modbus driver	
		License management system (LMU)	
SQL injection Web application	SQL injection occurs when malicious SQL code is inserted into an application's database query. A successful exploit allows an attacker to modify and read the application data.	Database interface	74
		Log files	
		Web interface	
Out-of-bounds Read	An out-of-bounds read occurs when the program unintentionally access data from adjacent memory locations. A successful exploit allows an attacker to read the memory data.	Data server	72
		Web interface	
		Application server	
Out-of-bounds Write	An out-of-bounds write occurs when the program overwrites adjacent memory locations. A successful exploit leads to memory modification, service disruption, and system crashes.	Logic controller editor	62
		HMI designer	
		Web interface	
		RTU	
		VNC (Virtual Network Computing)	
Improper access control	Improper access control occurs when the SCADA system fails to implement user privileges to users or resources. A successful exploit leads to information exposure, data modification, and malicious code execution.	NMS software application	49
		SCADA software	
		HMI	
		Configuration interface	
		User account management system in supervisory units.	
Heap-based buffer overflow	A heap-based buffer overflow occurs when the program inputs data on the allocated heap buffer exceeds the buffer size. It allows attackers to overwrite adjacent memory locations and run arbitrary code.	HMI editor	38
		SCADA node	
		Web application	
		Application server, OPC server	
Code, Command injection	Command injection occurs when an application does not properly validate or sanitize input data. A successful exploit can affect the SCADA system's availability, confidentiality, and integrity.	PLC management software	31
		Web adapter devices	
		SCADA software	
Lack of encryption	Lack of encryption occurs when a protection mechanism fails to encrypt sensitive data before storage or transmission. It allows an attacker to read and modify the application data if successfully exploited.	Network management system (NMS)	25
		IEC 61850 system configurator	
		ICS data	
		Communication channel	
Integer Overflow or Wraparound	An integer overflow vulnerability occurs when an integer variable stores a value that exceeds the maximum range of allocated memory. This vulnerability can occur when calculations are performed using integers without proper validation or error handling.	Remote access interfaces	3
		RTU	
		Web server	
		HMI	

Fig. 14. Common vulnerabilities targeting ICS components.

iteration of the S7 communication protocol involves a complex encryption process to protect the integrity of ICS data) [Alsabbagh and Langendörfer \(2023\)](#), [Hui et al. \(2021\)](#). Convert data into an encoded form that can only be read by authorised users. This is widely employed as a defensive mechanism to protect sensitive data, either stored in files

or transmitted over the network, from interception. It employs robust encryption mechanisms, including transport layer security and secure shell, to protect data during transmission. However, encryption might not be practical in the context of content-based solutions as it decreases the visibility of data to be evaluated by the mentoring tools ([Bartman](#)

and Carson, 2016). It might only work as a flow-based solution that only considers the amount of communications (Fauri et al., 2017). Additionally, it increases the troubleshooting and recovery cost since a full diagnosis requires the visibility of the communication content and possibly listening from various locations, to identify the source of the anomalous traffic. Moreover, an efficient ICS system should involve a proper complement of spare components where the operator can swap out easily for troubleshooting purposes. The lower visibility of data induced by encryption can negatively impact prompt replacement of components (Fauri et al., 2017).

Data integrity: Relying on the checksum alone for checking the data integrity is not a practical solution. An adversary can trick the operator by changing both the data value and the corresponding checksum value (Pidikiti et al., 2013). The National Cybersecurity Center of Excellence (NNCoE) and National Institute of Standards and Technology's (NIST) in collaboration with cyber security providers outlined practical security solutions that demonstrate how industrial sectors can protect the integrity of ICS data from a destructive malware (Powell et al., 2022). For example, VMware provides host-based application allowlisting (the blocking of unauthorised activities that have the potential to pose a harmful attack) and file integrity monitoring.

Network segmentation: Apply network segmentation to isolate critical data flows between different segments. This prevents unprivileged users from accessing the ICS network and mitigates potential security breaches' impacts.

Training and awareness: Provide cybersecurity training and awareness programs for ICS enablers. These are fundamental to expanding their knowledge about secure communication approaches. They provide a comprehensive understanding of ICS communication, including device to device, device to network, and network to network.

Applying these secure communication approaches helps organisations maintain the availability, confidentiality, and integrity of ICS systems. Thus, it establishes a secure communication environment that enhances the security level of ICSs.

7.14.8. Input sanitisation

Input sanitisation is an essential defensive approach for securing the integrity of ICS systems. It includes data sanitisation and validation of all user-supplied data. Thus, the approach prevents cyberattacks, including cross-site scripting, SQL injection, and code injection. Effective input sanitisation can be maintained as follows:

- **Input validation:** ICS systems have unique requirements, such as real-time processing, resource-constrained devices, and safety-critical operations, that make certain IT security practices impractical (Suaboot et al., 2020; Alanazi et al., 2023). In the context of ICS systems, devices and programs should validate the content of any remote parameter modification, including those from HMIs, control servers, or engineering workstations. Additionally, devices and programs that receive command messages from remote systems (e.g., control servers) should verify those commands before taking any actions on them (Alexander et al., 2020; MITRE, 2024).
- **Whitelisting approach:** When employing a whitelist method in ICS system, it is essential to consider all data types, amounts of data, and data structures integrated into the ICS software or application. Input validation techniques can help mitigate SQL, XSS, and command injection attacks. These techniques involve checking user inputs against predefined rules, such as range, length, division by zero, and format checks. IT IDS solutions often trigger alerts or block traffic based on known signatures. In ICS environments, false positives could lead to halting critical operations or causing safety issues.
- **Parametrised queries:** Use parametrised queries in which input values are passed as parameters. This splits the SQL queries from the user input values and no longer involves executable codes. Thus, SQL injection attacks are prevented because the parameters are treated as literal values and checked for length and type.

- **Input sanitisation techniques:** Employ input sanitisation defensive mechanisms to prevent XSS attacks. This involves handling special characters, filtering input, and removing malicious inputs from user values. Inputs are altered to ensure that they are valid and safe for display in the database. For example, HTML context can be encoded to prevent or mitigate the impacts of XSS attacks (Lakshmi et al., 2024).
- **Security testing:** Assess vulnerabilities on a regular basis. Existing ICS vulnerability scanning tools can halt the operation of ICS systems. Therefore, security analysts can employ manual assessment methods to identify and address vulnerabilities proactively (Ackerman, 2021).

Not all existing IT security measures are suitable for ICS systems due to the unique operational nature and characteristics of ICS environments. ICS systems require real-time performance to effectively control industrial processes, and any delays can lead to operational disruptions. For example, active vulnerability scanning can interfere with the operation of ICS equipment. IT IDS solutions often generate alerts or block traffic based on known signatures, which can result in false positives in ICS environments, potentially causing critical operational halts or safety issues.

Additionally, many ICS environments rely on legacy systems that were not designed to address modern cybersecurity threats. These systems often run on outdated hardware and software, lacking built-in security features (Weiss, 2010). Furthermore, ICS components typically have longer lifecycles than IT systems, sometimes operating for decades without hardware replacement. Consequently, security protocols designed for short-lifecycle IT systems may not be practical for ICS environments (McLaughlin et al., 2016b). Many ICS devices, such as PLCs, have limited processing power and storage capacity, which hinders the implementation of additional security features commonly used in general IT systems.

To address these constraints, there are alternative approaches that align better with ICS-specific constraints as follows:

- **Honeypots:** Deployed in ICS environments to attract and monitor attackers without impacting operational systems (Maesschalck et al., 2022).
- **Proper network architecture:** Segmentation, demilitarised zones (DMZs), and secure gateways can isolate sensitive ICS networks from external threats while allowing controlled, monitored interactions with IT systems (Ackerman, 2021).
- **Off-device monitoring:** Centralised or network-based security monitoring (e.g., intrusion detection systems and security information and event management, SIEM) can track traffic and detect anomalies without placing additional burdens on ICS devices themselves (Gaggero, 2022; Albasir et al., 2023).

8. Data quality evaluation metrics

Data quality refers to the extent to which a dataset meets specific criteria, including accuracy, completeness, validity, consistency, uniqueness, timeliness, and fitness for its intended purpose (Batini et al., 2009; Pipino et al., 2002). It plays a fundamental role in all data governance initiatives within an organisation. The importance of data quality has increased because of data processing being linked to business operations and the growing use of data to assist decision making. Thus, it helps organisations align data-driven decision making (DDDM) with their business goals. It aims to identify incorrect data and missing values and hence estimate their impacts on the business process.

In this section, we identify the quality issues in our dataset to evaluate completeness and uniqueness, assesses accuracy, and evaluate the variables' relevance. In Table 9, we present a detailed analysis of the evaluation metrics employed and their corresponding calculations. In Table 10, we validate the dataset's suitability for our analysis.

Table 9
Data quality evaluation metrics.

Evaluation metric	Description	Calculation value
Completeness	Completeness is the extent to which the dataset includes all elements without missing information. A high completeness score indicates fewer missing values.	Percentage of non-missing values
Accuracy	Accuracy measures the extent to which the data are correct and reliable. It compares the data values in the dataset to known data from external sources or ground truth.	Percentage of accurate values compared to a trusted source or ground truth
Consistency	Consistency is the extent to which the data are presented in the same format. A consistent dataset ensures that the data values align with their intended representations.	Percentage of consistent values among related variables
Uniqueness	Uniqueness is the extent to which a data point in our dataset is unique and does not have any duplicates. A high uniqueness score indicates minimal redundancy.	Percentage of unique values within a variable
Timeliness	It helps determine how current the data is, which is especially important for time-sensitive analyses.	Age of the data from creation or last update
Relevance	It evaluates how well the data align with the specific goals, objectives, or tasks at hand.	Relevant value

8.1. Completeness

Completeness is the extent to which the dataset includes all elements without missing information. Missing data can lead to inaccurate results in data analysis and decision-making processes. A high completeness value close to 1 indicates that the dataset is complete and suitable for analysis. A low completeness value (close to 0) indicates that the dataset has missing values, which may affect the validity and reliability of data analysis.

8.2. Accuracy

Accuracy measures the extent to which the data are correct and reliable. It compares the data values in the dataset to known data from external sources or ground truth. If the data in our dataset closely match the known data values, they are accurate. A feature accuracy value close to 1 indicates a match between the categorical value and its corresponding ground truth value.

8.3. Consistency

Consistency is the extent to which the data are presented in the same format (Pipino et al., 2002). A consistent dataset ensures that the data values align with their intended representations. Thus, it helps in DDDM and reliable analysis. A high consistency value close to 1 indicates a highly consistent dataset.

8.4. Uniqueness

Uniqueness is the extent to which a data point in our dataset is unique and does not have any duplicates. Measuring completeness prevents redundancy and maintains data integrity. A uniqueness value close to 1 indicates a distinct dataset with few duplicate entries.

8.5. Relevance

Relevance evaluates how well the data align with the specific goals, objectives, or tasks at hand. Irrelevant data may introduce noise and confusion, potentially leading to inaccurate results during analysis. A relevance value close to 1 means that the dataset contains relevant data, which is essential for making informed decisions.

9. Threats to validity

In this study, we aimed to assess threats to validity by analysing vulnerability data from reliable sources, such as the NVD and ICS-CERT. These sources provided valuable information about known vulnerabilities, exploits, and security incidents related to ICS systems and industrial control networks. By leveraging these data, we were able to identify and evaluate the validity of the threats that pose significant risks to critical infrastructure.

9.1. Internal validity

Internal validity refers to the degree to which the relationship between dependent variables and independent variables can be established. In our study, internal validity referred to the accuracy and reliability of the method used to collect and analyse ICS vulnerabilities. We employed a methodology that involved filtering vulnerability data from reliable sources, such as the NVD and ICS-CERT. We aimed to minimise potential threats to internal validity. However, limitations still existed and could influence the internal validity of our findings. One limitation that could impact internal validity was the reliance on publicly available vulnerability reports from sources such as the NVD and ICS-CERT. Some reports might not have captured all vulnerabilities or had delays leading to incomplete information. Additionally, our keyword-based filtering approach in identifying ICS vulnerabilities may have introduced biases if certain vulnerabilities had not been accurately captured. Therefore, it is important to declare these limitations in interpreting the results.

9.2. External validity

External validity refers to the generalisability of research findings to conditions beyond the specific context of a study. One aspect that can impact external validity is the representativeness of the data sources used. In our research, we relied on vulnerability reports from sources such as the NVD and ICS-CERT. While these sources are authoritative, it is essential to consider whether the vulnerabilities reported are representative of the entire ICS system. Thus, there were limitations to the external validity of our findings due to such factors as limited coverage of some industries, regions, or reporting practices across organisations. Another consideration for external validity was the generalisability of our findings to different ICS systems, architectures, or technologies. The vulnerabilities identified and the associated mitigation strategies

Table 10
ICS-LTU2022 dataset evaluation matrix.

Variable	Evaluation Metric	Calculation/Description
CVE_ID	Completeness, Uniqueness	100% (No missing values), (100% Uniqueness)
Assigned Year	Completeness	100% (No missing values)
CWE	Completeness	100% (No missing values)
Vendor	Completeness	100% (No missing values)
Attack vector	Completeness, Consistency	100% (No missing values), (100% Consistency)
User interaction	Completeness, Consistency	100% (No missing values), (100% Consistency)
Confidentiality impact	Completeness, Consistency	100% (No missing values), (100% Consistency)
Integrity impact	Completeness, Consistency	100% (No missing values), (100% Consistency)
Availability impact	Completeness, Consistency	100% (No missing values), (100% Consistency)
CVSS score	Completeness, Accuracy	100% (No missing values), (100% Accuracy)
Severity	Completeness, Consistency	100% (No missing values), (100% Consistency)
Affected products	Completeness, Relevance	100% (No missing values), (90% Relevance)
Industrial sector and regions	Relevance	90% Relevance
The entire dataset	Timeliness	100% for the past 8 years (from 2016–2023)

may vary depending on specific system configurations. Therefore, it is important to consider different ICS environments and their specific characteristics.

9.3. Construct validity

Construct validity refers to the extent to which a study accurately reflects the research questions and goals it aims to address. In our research, we focused on assessing the frequency of common security weaknesses in ICS components, industries, and regions. Public sources, including the NVD and ICS-CERT, served as our primary data sources for drawing conclusions about the most vulnerable ICS components. However, it is important to note that our findings were contingent upon the accuracy and comprehensiveness of the available sources. Thus, it is possible that some vulnerable components may not have been identified in the public data sources.

Notably, threats to validity depend not only on data sources but also on the methodologies used to analyse data. Hence, we employed cross-referenced multiple sources to validate the identified threats. This approach provided a comprehensive and accurate representation of the threats faced by ICS systems and enhanced the reliability of our findings.

10. Conclusion

Vulnerability assessment and risk management are vital cybersecurity mitigation approaches. The improvement of ICS vulnerability information can facilitate the development of risk management strategies by asset owners and the supply chain. Our findings show that most of the ICS system vulnerabilities are targeted to software and web applications, as these systems are directly connected to the internet. While a number of authoritative sources publish ICS vulnerabilities, these sources provide insufficient contextual information and means to identify trends and types of vulnerabilities that exist in ICSs. Therefore, ICS-LTU2022 can be used by the research community in the field of ICS risk assessment and analysis. It can be used to identify the trends of ICS vulnerabilities. It will be made public for ICS security researchers. We are in the process of developing an automated risk assessment framework that can reflect the risks and threats related to ICSs.

CRedit authorship contribution statement

Manar Alanazi: Writing – review & editing, Writing – original draft, Validation, Resources, Project administration, Methodology, Investigation. **Abdun Mahmood:** Supervision. **Mohammad Javed Morshed Chowdhury:** Supervision.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data availability

Data will be made available on request.

Acknowledgement

This work is supported by the Saudi Arabian Cultural Mission, Australia.

References

- Abou el Kalam, A., 2021. Securing SCADA and critical industrial systems: From needs to security mechanisms. *Int. J. Crit. Infrastruct. Prot.* 32, 100394.
- ACDA, C., 2023. AVEVA wonderware system platform. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-19-029-03>, (Accessed 10 August 2023).
- Ackerman, P., 2021. Industrial Cybersecurity: Efficiently Monitor the Cybersecurity Posture of Your ICS Environment. Packt Publishing Ltd.
- Ahmad, A., Hadgkiss, J., Ruighaver, A.B., 2012. Incident response teams—challenges in supporting the organisational security function. *Comput. Secur.* 31 (5), 643–652.
- Alanazi, M., Mahmood, A., Chowdhury, M.J.M., 2023. SCADA vulnerabilities and attacks: A review of the state of the art and open issues. *Comput. Secur.* 125, 103028. <http://dx.doi.org/10.1016/j.cose.2022.103028>, URL <https://www.sciencedirect.com/science/article/pii/S0167404822004205>.
- Albasir, A., Naik, K., Manzano, R., 2023. Toward improving the security of IoT and CPS devices: An AI approach. *Digit. Threats: Res. Pract.* 4 (2), 1–30.
- Alexander, O., Belisle, M., Steele, J., 2020. MITRE ATT&CK for Industrial Control Systems: Design and Philosophy. 29, The MITRE Corporation, Bedford, MA, USA.
- Ali, S., Al Balushi, T., Nadi, Z., Hussain, O.K., 2018. *Cyber Security for Cyber Physical Systems*. vol. 768, Springer.
- Almalawi, A., Yu, X., Tari, Z., Fahad, A., Khalil, I., 2014. An unsupervised anomaly-based detection approach for integrity attacks on SCADA systems. *Comput. Secur.* 46, 94–110. <http://dx.doi.org/10.1016/j.cose.2014.07.005>, URL <https://www.sciencedirect.com/science/article/pii/S0167404814001072>.
- Almukaynizi, M., Nunes, E., Dharaiya, K., Senguttuvan, M., Shakarian, J., Shakarian, P., 2017. Proactive identification of exploits in the wild through vulnerability mentions online. In: 2017 International Conference on Cyber Conflict (CyCon US). IEEE, Washington, USA, pp. 82–88. <http://dx.doi.org/10.1109/CYCONUS.2017.8167501>.
- Alsabbagh, W., Langendörfer, P., 2023. Security of programmable logic controllers and related systems: Today and tomorrow. *IEEE Open J. Ind. Electron. Soc.* 4, 659–693. <http://dx.doi.org/10.1109/OJIES.2023.3335976>.
- Almadi, I., Dwekat, Z., Cantu, R., Al-Ahmad, B., 2022. Vulnerability assessment of industrial systems using Shodan. *Cluster Comput.* 25 (3), 1563–1573.
- Andreeva, O., Gordeychik, S., Gritsai, G., Kochetova, O., Potseluevskaya, E., Sidorov, S.I., Timorin, A.A., 2016. Industrial control systems vulnerabilities statistics. Kaspersky Lab, Report.
- Anwar, A., Abusnaina, A., Chen, S., Li, F., Mohaisen, D., 2022. Cleaning the NVD: Comprehensive quality assessment, improvements, and analyses. *IEEE Trans. Dependable Secure Comput.* 19 (6), 4255–4269. <http://dx.doi.org/10.1109/TDSC.2021.3125270>.

- Ayub, A., Yoo, H., Ahmed, I., 2021. Empirical study of PLC authentication protocols in industrial control systems. In: 2021 IEEE Security and Privacy Workshops. SPW, IEEE, USA, pp. 383–397. <http://dx.doi.org/10.1109/SPW53761.2021.00058>.
- Bada, M., Pete, I., 2020. An exploration of the cybercrime ecosystem around shodan. In: 2020 7th International Conference on Internet of Things: Systems, Management and Security. IOTSMS, IEEE, France, pp. 1–8. <http://dx.doi.org/10.1109/IOTSMS52051.2020.9340224>.
- Bakeui, M., Flores, R., Remorin, L., Yarochkin, F., 2021. 2020 Report on Threats Affecting ICS Endpoints. Trend Micro, Japan, URL <https://www.key4biz.it/wp-content/uploads/2021/07/wp-2020-report-on-threats-affecting-critical-industrial-endpoints.pdf>.
- Bala, R., Nagpal, R., 2019. A review on kdd cup99 and nsl nsl-kdd dataset. *Int. J. Adv. Res. Comput. Sci.* 10 (2), p64–67.
- Banga, A., Gupta, D., Bathla, R., 2019. Towards a taxonomy of cyber attacks on scada system. In: 2019 International Conference on Intelligent Computing and Control Systems. ICCS, IEEE, Madurai, India, pp. 343–347. <http://dx.doi.org/10.1109/ICCS45141.2019.9065534>.
- Bartman, T., Carson, K., 2016. Securing communications for SCADA and critical industrial systems. In: 2016 69th Annual Conference for Protective Relay Engineers. CPRE, IEEE, College Station, TX, USA, pp. 1–10. <http://dx.doi.org/10.1109/CPRE.2016.7914914>.
- Basnet, M., Poudyal, S., Ali, M.H., Dasgupta, D., 2021. Ransomware detection using deep learning in the SCADA system of electric vehicle charging station. In: 2021 IEEE PES Innovative Smart Grid Technologies Conference - Latin America (ISGT Latin America). IEEE, Lima, Peru, pp. 1–5. <http://dx.doi.org/10.1109/ISGTLatinAmerica52371.2021.9543031>.
- Batini, C., Cappiello, C., Francalanci, C., Maurino, A., 2009. Methodologies for data quality assessment and improvement. *ACM Comput. Surv.* 41 (3), <http://dx.doi.org/10.1145/1541880.1541883>.
- Beaver, J.M., Borges-Hink, R.C., Buckner, M.A., 2013. An evaluation of machine learning methods to detect malicious SCADA communications. In: 2013 12th International Conference on Machine Learning and Applications. Vol. 2, IEEE, Miami, FL, USA, pp. 54–59. <http://dx.doi.org/10.1109/ICMLA.2013.105>.
- Beresford, D., 2011. Exploiting siemens simatic s7 plcs. *Black Hat USA* 16 (2), 723–733.
- Bhandari, G., Naseer, A., Moonen, L., 2021. Cvefixes: automated collection of vulnerabilities and their fixes from open-source software. In: Proceedings of the 17th International Conference on Predictive Models and Data Analytics in Software Engineering. In: PROMISE 2021, Association for Computing Machinery, New York, NY, USA, pp. 30–39. <http://dx.doi.org/10.1145/3475960.3475985>.
- Blinowski, G.J., Piotrowski, P., Wiśniewski, M., 2021. Comparing support vector machine and neural network classifiers of cve vulnerabilities. In: Proceedings of the 18th International Conference on Security and Cryptography - SECURITY. SciTePress, pp. 734–740. <http://dx.doi.org/10.5220/0010574807340740>.
- Bozorgi, M., Saul, L.K., Savage, S., Voelker, G.M., 2010. Beyond heuristics: Learning to classify vulnerabilities and predict exploits. In: Proceedings of the 16th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. KDD '10, Association for Computing Machinery, New York, NY, USA, pp. 105–114. <http://dx.doi.org/10.1145/1835804.1835821>.
- Bulle, B.B., Santin, A.O., Viegas, E.K., dos Santos, R.R., 2020. A host-based intrusion detection model based on OS diversity for SCADA. In: IECON 2020 the 46th Annual Conference of the IEEE Industrial Electronics Society. IEEE, Singapore, pp. 691–696. <http://dx.doi.org/10.1109/IECON43393.2020.9255062>.
- Carcano, A., Coletta, A., Guglielmi, M., Masera, M., Fovino, I.N., Trombetta, A., 2011. A multidimensional critical state analysis for detecting intrusions in SCADA systems. *IEEE Trans. Ind. Inform.* 7, 179–186, URL <https://api.semanticscholar.org/CorpusID:13933599>.
- Cárdenas, A.A., Amin, S., Lin, Z.-S., Huang, Y.-L., Huang, C.-Y., Sastry, S., 2011. Attacks against process control systems: risk assessment, detection, and response. In: ASIACCS '11: Proceedings of the 6th ACM Symposium on Information, Computer and Communications Security. ASIACCS '11, Association for Computing Machinery, New York, NY, USA, pp. 355–366. <http://dx.doi.org/10.1145/1966913.1966959>.
- Christey, S., Martin, R.A., 2007. Vulnerability type distributions in CVE. URL <http://cwe.mitre.org/documents/vuln-trends.html>.
- CISA, H., 2018. Open automation software OPC systems NET DLL hijacking vulnerability. CISA URL <https://www.cisa.gov/news-events/ics-advisories/icsa-15-344-02>.
- CISA, 2023a. ABB GATE-E2. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-18-352-01>, (Accessed 31 July 2023).
- CISA, 2023b. Advantech WebAccess HMI designer. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-20-219-02>, (Accessed 31 July 2023).
- CISA, 2023c. Advantech WebAccess node: CISA. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-20-128-01>, (Accessed 30 July 2023).
- CISA, 2023d. Advantech WebAccess vulnerabilities. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-16-014-01>, (Accessed 31 July 2023).
- CISA, 2023e. Advantech WebAccess/SCADA. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-075-01>, (Accessed 31 July 2023).
- CISA, 2023f. Advantech webop. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-17-227-01>, (Accessed 30 July 2023).
- CISA, 2023g. Automation direct CLICK PLC CPU modules. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-166-02>, (Accessed 30 July 2023).
- CISA, 2023h. AVEVA enterprise data management web. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-20-254-01>, (Accessed 31 July 2023).
- CISA, 2023i. FATEK automation WinProLadder. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-175-01>, (Accessed 31 July 2023).
- CISA, 2023j. Honeywell ControlEdge PLC and RTU. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-20-175-02>, (Accessed 30 July 2023).
- CISA, 2023k. Horner automation cscape. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-112-01>, (Accessed 3 August 2023).
- CISA, 2023l. Horner automation cscape csfont. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-22-146-02>, Accessed 30 July 2023.
- CISA, 2023m. Kunbus PR100088 modbus gateway (update B). URL <https://www.cisa.gov/news-events/ics-advisories/icsa-19-036-05>, (Accessed 31 July 2023).
- CISA, 2023n. LCDS - leão consultoria e desenvolvimento de sistemas ltda ME laquis SCADA. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-18-298-02>, (Accessed 31 July 2023).
- CISA, 2023o. Modbus tools modbus slave. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-22-088-04>, (Accessed 28 July 2023).
- CISA, 2023p. mySCADA myPRO. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-217-03>, (Accessed 3 August 2023).
- CISA, 2023q. Phoenix contact ILC PLC authentication vulnerabilities. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-16-313-01>, (Accessed 31 July 2023).
- CISA, 2023r. Rockwell automation CompactLogix 5370. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-19-120-01>, (Accessed 31 July 2023).
- CISA, 2023s. Rockwell automation studio 5000 logix designer. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-22-090-07>, (Accessed 31 July 2023).
- CISA, 2023t. Siemens S7-400 CPUs. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-18-317-02>, (Accessed 30 July 2023).
- CISA, 2023u. Siemens SICAM. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-17-320-02>, (Accessed 31 July 2023).
- CISA, 2023v. Siemens SRCs VPN feature in SIMATIC CP devices (update A). URL <https://www.cisa.gov/news-events/ics-advisories/icsa-22-195-12>, (Accessed 31 July 2023).
- CISA, 2023w. Vulnerability summary for the week of august 31, 2020. URL <https://www.cisa.gov/news-events/bulletins/sb20-251>, (Accessed 31 July 2023).
- CISA, 2023x. WECON PLC editor. URL <https://www.cisa.gov/news-events/ics-advisories/icsa-21-315-01>, (Accessed 28 July 2023).
- Colbert, E.J., Kott, A., 2016. Cyber-Security of SCADA and Other Industrial Control Systems. vol. 66, Springer.
- Conklin, W.A., 2016. IT vs. OT security: A time to consider a change in CIA to include resiliency. In: 2016 49th Hawaii International Conference on System Sciences. HICSS, IEEE, Koloa, HI, USA, pp. 2642–2647. <http://dx.doi.org/10.1109/HICSS.2016.331>.
- Eckhart, M., Ekelhart, A., Lüder, A., Biffl, S., Weippl, E., 2019. Security development lifecycle for cyber-physical production systems. In: IECON 2019 - 45th Annual Conference of the IEEE Industrial Electronics Society. Vol. 1, IEEE, Portugal, pp. 3004–3011. <http://dx.doi.org/10.1109/IECON.2019.8927590>.
- Edkrantz, M., Said, A., 2015. Predicting cyber vulnerability exploits with machine learning. In: Thirtieth Scandinavian Conference on Artificial Intelligence SCAI. IOS Press, Sweden, pp. 48–57.
- Empl, P., Schlette, D., Stöger, L., Pernul, G., 2024. Generating ICS vulnerability playbooks with open standards. *Int. J. Inf. Secur.* 23 (2), 1215–1230.
- Etzioni, A., 2014. The private sector: A reluctant partner in cybersecurity. *Geo. J. Int'l Aff.* 15, 69.
- Faramondi, L., Flammini, F., Guarino, S., Setola, R., 2021. A hardware-in-the-loop water distribution testbed dataset for cyber-physical security testing. *IEEE Access* 9, 122385–122396. <http://dx.doi.org/10.1109/ACCESS.2021.3109465>.
- Fauri, D., de Wijs, B., den Hartog, J., Costante, E., Zambon, E., Etalle, S., 2017. Encryption in ICS networks: A blessing or a curse? In: 2017 IEEE International Conference on Smart Grid Communications (SmartGridComm). IEEE, Germany, pp. 289–294.
- Franco, D.J., Muhammed, A.B., Subramaniam, S.K., Abdullah, A., Silva, R.M., Akram, O.K., 2019. A review on current and old SCADA networks applied to water distribution systems. In: 2019 First International Conference of Intelligent Computing and Engineering. ICOICE, IEEE, Hadhramout, Yemen, pp. 1–11. <http://dx.doi.org/10.1109/ICOICE48418.2019.9035134>.
- Gaggero, G.B., 2022. Machine learning based anomaly detection for cybersecurity monitoring of critical infrastructures.
- Gharib, A., Sharafaldin, I., Lashkari, A.H., Ghorbani, A.A., 2016. An evaluation framework for intrusion detection dataset. In: 2016 International Conference on Information Science and Security. ICISSE, IEEE, pp. 1–6. <http://dx.doi.org/10.1109/ICISSE.2016.7885840>.
- Ghurab, M., Gaphari, G., Alshami, F., Alshamy, R., Othman, S., 2021. A detailed analysis of benchmark datasets for network intrusion detection system. *Asian J. Res. Comput. Sci.* 7 (4), 14–33.
- Gkortzis, A., Mitropoulos, D., Spinellis, D., 2018. Vulinoss: a dataset of security vulnerabilities in open-source systems. In: MSR '18: Proceedings of the 15th International Conference on Mining Software Repositories. MSR '18, Association for Computing Machinery, New York, NY, USA, pp. 18–21. <http://dx.doi.org/10.1145/3196398.3196454>.
- Golrang, A., Golrang, A.M., Yildirim Yayilgan, S., Elezaj, O., 2020. A novel hybrid IDS based on modified NSGAII-ANN and random forest. *electronics* 9 (4), 577.

- Graff, M., Van Wyk, K.R., 2003. Secure Coding: Principles and Practices. "O'Reilly Media, Inc."
- Guevara, I., Fradkin, C., 2021. Growing ICS vulnerabilities mandate prioritization: Use vulnerability management at the convergence of information and operational technologies to lower risk to industrial control systems. *Control Eng.* 68 (2), 31–34.
- Hadžiosmanović, D., Sommer, R., Zambon, E., Hartel, P.H., 2014. Through the eye of the PLC: semantic security monitoring for industrial processes. In: ACSAC14 Proceedings of the 30th Annual Computer Security Applications Conference. ACSAC '14, Association for Computing Machinery, New York, NY, USA, pp. 126–135. <http://dx.doi.org/10.1145/2664243.2664277>.
- Hoque, M.S., Jamil, N., Amin, N., Lam, K.-Y., 2021. An improved vulnerability exploitation prediction model with novel cost function and custom trained word vector embedding. *Sensors* 21 (12), <http://dx.doi.org/10.3390/s21124220>, URL <https://www.mdpi.com/1424-8220/21/12/4220>.
- Housen-Couriel, D., 2018. Information sharing for the mitigation of hostile activity in cyberspace: Comparing two nascent models (part 1). *Eur. Cybersecur. J.* 4 (3), 44–50.
- Howland, H., 2023. Cvss: Ubiquitous and broken. *Digit. Threats: Res. Pract.* 4 (1), 1–12. <http://dx.doi.org/10.1145/3491263>.
- HSGAC, 2021. Use of cryptocurrency in ransomware attacks, available data, and national security concerns. URL https://www.hsgac.senate.gov/wp-content/uploads/imo/media/doc/HSGAC%20Majority%20Cryptocurrency%20Ransomware%20Report_Executive%20Summary.pdf.
- Hui, H., McLaughlin, K., Sezer, S., 2021. Vulnerability analysis of S7 PLCs: Manipulating the security mechanism. *Int. J. Crit. Infrastruct. Prot.* 35, 100470. <http://dx.doi.org/10.1016/j.ijcip.2021.100470>, URL <https://www.sciencedirect.com/science/article/pii/S1874548221000573>.
- Humphrey, M., 2017. Identifying the Critical Success Factors to Improve Information Security Incident Reporting (Ph.D. thesis). Cranfield University.
- Igre, V.M., Laughter, S.A., Williams, R.D., 2006. Security issues in SCADA networks. *Comput. Secur.* 25 (7), 498–506. <http://dx.doi.org/10.1016/j.cose.2006.03.001>, URL <https://www.sciencedirect.com/science/article/pii/S0167404806000514>.
- Jabez, J., Muthukumar, B., 2015. Intrusion detection system (IDS): Anomaly detection using outlier detection approach. *Procedia Comput. Sci.* 48, 338–346. <http://dx.doi.org/10.1016/j.procs.2015.04.191>, URL <https://www.sciencedirect.com/science/article/pii/S1877050915007000>, International Conference on Computer, Communication and Convergence (ICCC 2015).
- Jimenez, M., Le Traon, Y., Papadakis, M., 2018. [Engineering paper] enabling the continuous analysis of security vulnerabilities with VulData7. In: 2018 IEEE 18th International Working Conference on Source Code Analysis and Manipulation. SCAM, IEEE, Madrid, Spain, pp. 56–61. <http://dx.doi.org/10.1109/SCAM.2018.00014>.
- Johnson, R.E., 2010. Survey of SCADA security challenges and potential attack vectors. In: 2010 International Conference for Internet Technology and Secured Transactions. IEEE, London, UK, pp. 1–5.
- Jung, W.-C., Kim, J., Park, N., 2021. Web-browsing application using web scraping technology in Korean network separation application. *Symmetry* 13 (8), 1550.
- Kant, D., Creutzburg, R., Johannsen, A., 2020. Investigation of risks for critical infrastructures due to the exposure of SCADA systems and industrial controls on the internet based on the search engine shodan. *Electron. Imaging* 2020 (3), 1–16. <http://dx.doi.org/10.2352/ISSN.2470-1173.2020.3.MOBMU-253>.
- Karatas, G., Demir, O., Sahingöz, O.K., 2020. Increasing the performance of machine learning-based IDSs on an imbalanced and up-to-date dataset. *IEEE Access* 8, 32150–32162. <http://dx.doi.org/10.1109/ACCESS.2020.2973219>.
- Khalil, S.M., Bahsi, H., Korötko, T., 2023. Threat modeling of industrial control systems: A systematic literature review. *Comput. Secur.* 103543.
- Kilman, D., Stamp, J., 2005. Framework for SCADA security policy. Sandia National Laboratories report SAND2005-1002C.
- Kissel, R., Stine, K.M., Scholl, M.A., Rossman, H., Fahlsing, J., Gulick, J., 2008. Sp 800-64 rev. 2. security considerations in the system development life cycle.
- Klahr, R., Shah, J., Sheriffs, P., Rossington, T., Pestell, G., Button, M., Wang, V., 2017. Cyber security breaches survey. In: A Survey Detailing Business Action or Cyber Security and the Costs and Impacts of Cyber Breaches and Attacks. 2017, Department for Culture, Media; Sport, United Kingdom.
- Klick, J., Lau, S., Marzin, D., Malchow, J.-O., Roth, V., 2015. Internet-facing PLCs as a network backdoor. In: 2015 IEEE Conference on Communications and Network Security. CNS, IEEE, Florence, Italy, pp. 524–532. <http://dx.doi.org/10.1109/CNS.2015.7346865>.
- Kuehn, P., Bayer, M., Wendelborn, M., Reuter, C., 2021. OVANA: An approach to analyze and improve the information quality of vulnerability databases. In: Proceedings of the 16th International Conference on Availability, Reliability and Security. ARES '21, Association for Computing Machinery, New York, NY, USA, p. 22. <http://dx.doi.org/10.1145/3465481.3465744>.
- Kuipers, D., Fabro, M., 2006. Control systems cyber security: Defense in depth strategies. Technical Report, Idaho National Lab.(INL), Idaho Falls, ID (United States).
- Labrotary, L., 1999. DARPA Intrusion Detection Evaluation Data Set. 12, Massachusetts Institute of technology. Retrieved January, Cambridge, MA, p. 2009.
- Lakshmi, B.S., Kovvuri, D., Boliseti, H.N.V., Chikkala, D.S., Karri, S., Yadlapalli, G., 2024. A proactive approach for detecting SQL and XSS injection attacks. In: 2024 3rd International Conference on Applied Artificial Intelligence and Computing. ICAAIC, IEEE, Salem, India, pp. 1415–1420. <http://dx.doi.org/10.1109/ICAAIC60222.2024.10575599>.
- Larkin, R.D., Lopez Jr., J., Butts, J.W., Grimaila, M.R., 2014. Evaluation of security solutions in the SCADA environment. *ACM SIGMIS Database: DATABASE Adv. Inf. Syst.* 45 (1), 38–53.
- Lee, J.-M., Hong, S., 2021. Host-oriented approach to cyber security for the scada systems. In: 2020 6th IEEE Congress on Information Science and Technology (CiSt). IEEE, Morocco, pp. 151–155. <http://dx.doi.org/10.1109/CiSt49399.2021.9357299>.
- Lee, W., Stolfo, S.J., Mok, K.W., 1999. Mining in a data-flow environment: Experience in network intrusion detection. In: Proceedings of the Fifth ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. Association for Computing Machinery ACM, USA, pp. 114–124.
- Lika, R.A., Murugiah, D., Brohi, S.N., Ramasamy, D., 2018. NotPetya: Cyber attack prevention through awareness via gamification. In: 2018 International Conference on Smart Computing and Electronic Enterprise. ICSCEE, IEEE, Malaysia, pp. 1–6. <http://dx.doi.org/10.1109/ICSCEE.2018.8538431>.
- Maesschalck, S., Giotas, V., Green, B., Race, N., 2022. Don't get stung, cover your ICS in honey: How do honeypots fit within industrial control system security. *Comput. Secur.* 114, 102598.
- Makrakis, G.M., Kolias, C., Kambourakis, G., Rieger, C., Benjamin, J., 2021. Industrial and critical infrastructure security: Technical analysis of real-life security incidents. *IEEE Access* 9, 165295–165325. <http://dx.doi.org/10.1109/ACCESS.2021.3133348>.
- McHugh, J., 2000. Testing intrusion detection systems: A critique of the 1998 and 1999 NSL-KDDA intrusion detection system evaluations as performed by lincoln laboratory. *ACM Trans. Inf. Syst. Secur.* 3 (4), 262–294. <http://dx.doi.org/10.1145/382912.382923>.
- McLaughlin, S., Konstantinou, C., Wang, X., Davi, L., Sadeghi, A.-R., Maniatakis, M., Karri, R., 2016a. The cybersecurity landscape in industrial control systems. *Proc. IEEE* 104 (5), 1039–1057. <http://dx.doi.org/10.1109/JPROC.2015.2512235>.
- McLaughlin, S., Konstantinou, C., Wang, X., Davi, L., Sadeghi, A.-R., Maniatakis, M., Karri, R., 2016b. The cybersecurity landscape in industrial control systems. *Proc. IEEE* 104 (5), 1039–1057.
- Meena, G., Choudhary, R.R., 2017. A review paper on IDS classification using KDD 99 and NSL kdd dataset in WEKA. In: 2017 International Conference on Computer, Communications and Electronics (Comptelix). IEEE, India, pp. 553–558. <http://dx.doi.org/10.1109/COMPTELIX.2017.8004032>.
- Miller, B., Rowe, D., 2012. A survey SCADA of and critical infrastructure incidents. In: Proceedings of the 1st Annual Conference on Research in Information Technology. Association for Computing Machinery, New York, NY, USA, pp. 51–56. <http://dx.doi.org/10.1145/2380790.2380805>.
- Miller, T., Staves, A., Maesschalck, S., Sturdee, M., Green, B., 2021. Looking back to look forward: Lessons learnt from cyber-attacks on industrial control systems. *Int. J. Crit. Infrastruct. Prot.* 35, 100464. <http://dx.doi.org/10.1016/j.ijcip.2021.100464>, URL <https://www.sciencedirect.com/science/article/pii/S1874548221000524>.
- MITRE, 2024. ICS matrix. URL <https://attack.mitre.org/matrices/ics/>, Accessed 08 April 2024.
- Morris, T., Gao, W., 2014. Industrial control system traffic data sets for intrusion detection research. In: Butts, J., Shenoi, S. (Eds.), *Critical Infrastructure Protection VIII*. Springer Berlin Heidelberg, Berlin, Heidelberg, pp. 65–78.
- Morris, T.H., Thornton, Z., Turnipseed, I., 2015. Industrial control system simulation and data logging for intrusion detection system research. In: 7th Annual Southeastern Cyber Security Summit. CAE, Huntsville, AL, pp. 3–4.
- Morris, T., Vaughn, R., Dandass, Y.S., 2011. A testbed for SCADA control system cybersecurity research and pedagogy. In: Proceedings of the Seventh Annual Workshop on Cyber Security and Information Intelligence Research. Association for Computing Machinery, NY, USA, p. 1.
- Moustafa, N., Slay, J., 2015. UNSW-NB15: a comprehensive data set for network intrusion detection systems (UNSW-NB15 network data set). In: 2015 Military Communications and Information Systems Conference (MilCIS). IEEE, Canberra, Australia, pp. 1–6.
- Mubarak, S., Habaebi, M.H., Islam, M.R., Rahman, F.D.A., Tahir, M., 2021. Anomaly detection in ICS datasets with machine learning algorithms. *Comput. Syst. Sci. Eng.* 37 (1).
- Nair, A., Ray, A., Reddy, L., Marali, M., 2022. Mapping of CVE-ID to tactic for comprehensive vulnerability management of ICS. In: *Inventive Communication and Computational Technologies: Proceedings of ICICCT 2022*. Springer, pp. 559–571.
- Neuhauss, S., Zimmermann, T., 2010. Security trend analysis with CVE topic models. In: 2010 IEEE 21st International Symposium on Software Reliability Engineering. IEEE, USA, pp. 111–120. <http://dx.doi.org/10.1109/ISSRE.2010.53>.
- Newman, D., 1999. KDD cup'99 data sets. Retrieved February 7, 2010.
- Ortega-Fernandez, I., Sestelo, M., Burguillos, J.C., Pinon-Blanco, C., 2023. Network intrusion detection system for DDoS attacks in ICS using deep autoencoders. *Wirel. Netw.* 1–17.
- Osman, F.A., Hashem, M.Y., Eltokhy, M.A., 2022. Secured cloud SCADA system implementation for industrial applications. *Multimedia Tools Appl.* 81 (7), 9989–10005.

- Paridari, K., O'Mahony, N., El-Din Mady, A., Chabukswar, R., Boubekeur, M., Sandberg, H., 2018. A framework for attack-resilient industrial control systems: Attack detection and controller reconfiguration. *Proc. IEEE* 106 (1), 113–128. <http://dx.doi.org/10.1109/JPROC.2017.2725482>.
- Park, J., Sandhu, R., Gupta, M., Bhatt, S., 2021. Activity control design principles: Next generation access control for smart and collaborative systems. *IEEE Access* 9, 151004–151022. <http://dx.doi.org/10.1109/ACCESS.2021.3126201>.
- Pham, V., Dang, T., 2018. CVExplorer: Multidimensional visualization for common vulnerabilities and exposures. In: 2018 IEEE International Conference on Big Data (Big Data). IEEE, Seattle, WA, USA, pp. 1296–1301. <http://dx.doi.org/10.1109/BigData.2018.8622092>.
- Pidikiti, D.S., Kalluri, R., Kumar, R.S., Bindhumadhava, B., 2013. SCADA communication protocols: vulnerabilities, attacks and possible mitigations. *CSI Trans. ICT* 1 (2), 135–141.
- Pipino, L.L., Lee, Y.W., Wang, R.Y., 2002. Data quality assessment. *Commun. ACM* 45 (4), 211–218. <http://dx.doi.org/10.1145/505248.506010>.
- Pliatsios, D., Sarigiannidis, P., Lagkas, T., Sarigiannidis, A.G., 2020. A survey on SCADA systems: secure protocols, incidents, threats and tactics. *IEEE Commun. Surv. Tutor.* 22 (3), 1942–1976.
- Ponta, S.E., Plate, H., Sabetta, A., Bezzi, M., Dangremont, C., 2019. A manually-curated dataset of fixes to vulnerabilities of open-source software. In: 2019 IEEE/ACM 16th International Conference on Mining Software Repositories. MSR, IEEE, Canada, pp. 383–387. <http://dx.doi.org/10.1109/MSR.2019.00064>.
- Pooja, T., Shrinivasacharya, P., 2021. Evaluating neural networks using Bi-Directional LSTM for network IDS (intrusion detection systems) in cyber security. *Global Transitions Proceedings* 2 (2), 448–454. <http://dx.doi.org/10.1016/j.gltp.2021.08.017>, International Conference on Computing System and its Applications (ICCSA-2021).
- Powell, M., Brule, J., Pease, M., Stouffer, K., Tang, C., Zimmerman, T., Deane, C., Hoyt, J., Raguso, M., Sherule, A., et al., 2022. Protecting information and system integrity in industrial control system environments.
- Qi, J., Zhang, X., McCarty, G.W., Sadeghi, A.M., Cosh, M.H., Zeng, X., Gao, F., Daughtry, C.S., Huang, C., Lang, M.W., Arnold, J.G., 2018. Assessing the performance of a physically-based soil moisture module integrated within the soil and water assessment tool. *Environ. Model. Softw.* 109, 329–341. <http://dx.doi.org/10.1016/j.envsoft.2018.08.024>.
- Raj, G., Singh, D., Bansal, A., 2014. Analysis for security implementation in SDLC. In: 2014 5th International Conference - Confluence the Next Generation Information Technology Summit (Confluence). pp. 221–226. <http://dx.doi.org/10.1109/CONFLUENCE.2014.6949376>.
- Reinthal, A., Filippakis, E.L., Almgren, M., 2018. Data modelling for predicting exploits. In: Gruschka, N. (Ed.), *Secure IT Systems*. Springer International Publishing, Cham, pp. 336–351.
- Revathi, S., Malathi, A., 2013. A detailed analysis on NSL-KDD dataset using various machine learning techniques for intrusion detection. *Int. J. Eng. Res. Technol. (IJERT)* 2 (12), 1848–1853.
- Rodofle, N.R., Radke, K., Foo, E., 2017. Framework for SCADA cyber-attack dataset creation. In: Proceedings of the Australasian Computer Science Week Multiconference. ACSW '17, Association for Computing Machinery, New York, NY, USA, p. 69. <http://dx.doi.org/10.1145/3014812.3014883>.
- Rodriguez, L.G.A., Trazzi, J.S., Fossaluzza, V., Campiolo, R., Batista, D.M., 2018. Analysis of vulnerability disclosure delays from the national vulnerability database. In: Workshop de Segurança Cibernética em Dispositivos Conectados. WSCDC, SBC.
- Rossberg, J., 2014. *Beginning Application Lifecycle Management*. A Press.
- Ruefle, R., Dorofee, A., Mundie, D., Householder, A.D., Murray, M., Perl, S.J., 2014. Computer security incident response team development and evolution. *IEEE Secur. Privacy* 12 (5), 16–26. <http://dx.doi.org/10.1109/MSP.2014.89>.
- Rytel, M., Felkner, A., Janiszewski, M., 2020. Towards a safer internet of things—A survey of IoT vulnerability data sources. *Sensors* 20 (21), 5969.
- Sajid, A., Abbas, H., Saleem, K., 2016. Cloud-assisted IoT-based SCADA systems security: A review of the state of the art and future challenges. *IEEE Access* 4, 1375–1384. <http://dx.doi.org/10.1109/ACCESS.2016.2549047>.
- Scott, M.J., CIPC, C., 2023. Protecting industrial control system software with secure coding practices. ISACA.
- Seacord, R.C., 2013. *Secure Coding in C and C++*. Addison-Wesley.
- Sindhwad, P.V., Samant, M., Kazi, F., 2022. Security challenges in cyber physical system communication protocols: Empirical analysis based on disclosed vulnerabilities. In: 2022 IEEE International Conference on Advanced Networks and Telecommunications Systems. ANTS, IEEE, Gandhinagar, Gujarat, India, pp. 464–469. <http://dx.doi.org/10.1109/ANTS56424.2022.10227797>.
- Smith, L.J., 2019. Estimating Security Risk in Open Source Package Repositories: An Empirical Analysis and Predictive Model of Software Vulnerabilities (Ph.D. thesis). Capella University.
- Stouffer, K., Falco, J., Scarfone, K., et al., 2011. Guide to industrial control systems (ICS) security. NIST Special Publication 800 (82), 16.
- Su, T., Sun, H., Zhu, J., Wang, S., Li, Y., 2020. BAT: Deep learning methods on network intrusion detection using NSL-kdd dataset. *IEEE Access* 8, 29575–29585. <http://dx.doi.org/10.1109/ACCESS.2020.2972627>.
- Suaboot, J., Fahad, A., Tari, Z., Grundy, J., Mahmood, A.N., Almalawi, A., Zomaya, A.Y., Drira, K., 2020. A taxonomy of supervised learning for ids in scada environments. *ACM Comput. Surv.* 53 (2), 1–37. <http://dx.doi.org/10.1145/3379499>.
- Susantha, K., Lu, D., Wang, X., 2023. Lessons learned from previous cyberattacks on energy systems—global and Australian context. In: 2023 IEEE International Future Energy Electronics Conference. IFEEEC, IEEE, Sydney, Australia, pp. 550–554. <http://dx.doi.org/10.1109/IFEEEC58486.2023.10458537>.
- Taormina, R., Galelli, S., Tippenhauer, N.O., Salomons, E., Ostfeld, A., 2017. Characterizing cyber-physical attacks on water distribution systems. *J. Water Resour. Plan. Manag.* 143 (5), 04017009.
- Tavabi, N., Goyal, P., Almukaynizi, M., Shakarian, P., Lerman, K., 2018. DarkEmbed: Exploit prediction with neural language models. In: Proceedings of the AAAI Conference on Artificial Intelligence. Vol. 32, AAAI, California, USA, pp. 49–52. <http://dx.doi.org/10.1609/aaai.v32i1.11428>, URL <https://ojs.aaai.org/index.php/AAAI/article/view/11428>.
- Tavallae, M., Bagheri, E., Lu, W., Ghorbani, A.A., 2009a. A detailed analysis of the KDD cup 99 data set. In: 2009 IEEE Symposium on Computational Intelligence for Security and Defense Applications. IEEE, Barcelona, Spain, pp. 1–6.
- Tavallae, M., Bagheri, E., Lu, W., Ghorbani, A.A., 2009b. A detailed analysis of the kdd cup 99 dataset. In: 2009 IEEE Symposium on Computational Intelligence for Security and Defense Applications. IEEE, Ottawa, ON, Canada, pp. 1–6. <http://dx.doi.org/10.1109/CISDA.2009.5356528>.
- Tellabi, A., Sassmanhausen, J., Bajramovic, E., Ruland, K.C., 2018. Overview of authentication and access controls for ICS systems. In: 2018 IEEE 16th International Conference on Industrial Informatics. INDIN, IEEE, Portugal, pp. 882–889. <http://dx.doi.org/10.1109/INDIN.2018.8472068>.
- Thomas, R.J., Chothia, T., 2020. Learning from vulnerabilities-categorising, understanding and detecting weaknesses in industrial control systems. In: *Computer Security: ESORICS 2020 International Workshops, CyberICPS, SECPRE, and ADIoT*, Guildford, UK, September 14–18, 2020, Revised Selected Papers 6. Springer, Cham, pp. 100–116.
- Thomas, R.J., Gardiner, J., Chothia, T., Samanis, E., Perrett, J., Rashid, A., 2020a. Catch me if you can: An in-depth study of CVE discovery time and inconsistencies for managing risks in critical infrastructures. In: Proceedings of the 2020 Joint Workshop on CPS&IoT Security and Privacy. CPSIoTSEC '20, Association for Computing Machinery, New York, NY, USA, pp. 49–60. <http://dx.doi.org/10.1145/3411498.3419970>.
- Thomas, R.J., Gardiner, J., Chothia, T., Samanis, E., Perrett, J., Rashid, A., 2020b. Catch me if you can: An in-depth study of CVE discovery time and inconsistencies for managing risks in critical infrastructures. In: Proceedings of the 2020 Joint Workshop on CPS&IoT Security and Privacy. CPSIoTSEC '20, Association for Computing Machinery, New York, NY, USA, pp. 49–60. <http://dx.doi.org/10.1145/3411498.3419970>.
- Upadhyay, D., Sampalli, S., 2020. SCADA (supervisory control and data acquisition) systems: Vulnerability assessment and security recommendations. *Comput. Secur.* 89, 101666. <http://dx.doi.org/10.1016/j.cose.2019.101666>, URL <https://www.sciencedirect.com/science/article/pii/S0167404819302068>.
- Ur-Rehman, A., Gondal, I., Kamruzzaman, J., Jolfaei, A., 2020. Vulnerability modelling for hybrid industrial control system networks. *J. Grid Comput.* 18, 863–878.
- Venugopal, V., Alves-Foss, J., Ravindrababu, S.G., 2019. Use of an SDN switch in support of NIST ICS security recommendations and least privilege networking. In: Proceedings of the Fifth Annual Industrial Control System Security (ICSS) Workshop. NIST, USA, pp. 11–20.
- Weiss, J., 2010. Protecting Industrial Control Systems from Electronic Threats. Momentum Press.
- Wermann, A.G., Bortolozzo, M.C., Germano da Silva, E., Schaeffer-Filho, A., Paschoal Gaspar, L., Barcellos, M., 2016. ASTORIA: A framework for attack simulation and evaluation in smart grids. In: NOMS 2016 - 2016 IEEE/IFIP Network Operations and Management Symposium. IEEE, Istanbul, Turkey, pp. 273–280. <http://dx.doi.org/10.1109/NOMS.2016.7502822>.
- Williams, M.A., Barranco, R.C., Naim, S.M., Dey, S., Shahriar Hossain, M., Akbar, M., 2020. A vulnerability analysis and prediction framework. *Comput. Secur.* 92, 101751. <http://dx.doi.org/10.1016/j.cose.2020.101751>, URL <https://www.sciencedirect.com/science/article/pii/S0167404820300353>.
- Williams, M.A., Dey, S., Barranco, R.C., Naim, S.M., Hossain, M.S., Akbar, M., 2018. Analyzing evolving trends of vulnerabilities in national vulnerability database. In: 2018 IEEE International Conference on Big Data (Big Data). IEEE, Seattle, WA, USA, pp. 3011–3020. <http://dx.doi.org/10.1109/BigData.2018.8622299>.
- Williams, T.J., et al., 1989. A reference model for computer integrated manufacturing (CIM). *International Purdue Works* 25.
- Wu, Y., Song, S., Zhuge, J., Yin, T., Li, T., Zhu, J., Guo, G., Liu, Y., Hu, J., 2021. Icscope: Detecting and measuring vulnerable ICS devices exposed on the internet. In: International Conference on Information Systems Security and Privacy. Springer, Cham, -, pp. 1–24. http://dx.doi.org/10.1007/978-3-031-37807-2_1.
- Wueest, C., 2014. Targeted attacks against the energy sector. Symantec Security Response, Mountain View, CA.
- Yadav, G., Paul, K., 2021. Architecture and security of SCADA systems: A review. *Int. J. Crit. Infrastruct. Prot.* 34, 100433. <http://dx.doi.org/10.1016/j.ijcip.2021.100433>, URL <https://www.sciencedirect.com/science/article/pii/S1874548221000251>.

- Zaman, M., Upadhyay, D., Lung, C.-H., 2023. Validation of a machine learning-based IDS design framework using ORNL datasets for power system with SCADA. *IEEE Access* 11, 118414–118426. <http://dx.doi.org/10.1109/ACCESS.2023.3326751>.
- Zardasti, L., Yahaya, N., Valipour, A., Rashid, A.S.A., Noor, N.M., 2017. Review on the identification of reputation loss indicators in an onshore pipeline explosion event. *J. Loss Prev. Process Ind.* 48, 71–86.
- Zhang, S., Caragea, D., Ou, X., 2011. An empirical study on using the national vulnerability database to predict software vulnerabilities. In: *International Conference on Database and Expert Systems Applications*. Springer, Berlin, Heidelberg, pp. 217–231.
- Zohrevand, Z., Glasser, U., Shahir, H.Y., Tayebi, M.A., Costanzo, R., 2016. Hidden Markov based anomaly detection for water supply systems. In: *2016 IEEE International Conference on Big Data (Big Data)*. IEEE, Washington, DC, USA, pp. 1551–1560. <http://dx.doi.org/10.1109/BigData.2016.7840763>.